API Architecture

NHS Pathways Transformation

5 November, 2026

Table of Contents

1 Aggregated /_status Health Check – Design 7
1.1 1. Background and Problem Statement 7
1.1.1 Routing rules today 7
1.2 3. Architecture Diagram 8
1.3 /_status Request 8
1.4 Successful Response 9
1.5 Unsuccessful Response 9
1.6 4. Component Design 9
1.6.1 4.2 Health check logic 9
1.6.2 4.3 Aggregated HTTP response 10
1.7 5. Decision: Lambda vs Step Functions 10
1.8 6. Extensibility 11
2 API High Level Design 12
2.1 Triage API 12
2.1.1 Triage API - C4 Diagrams 12
2.1.2 Triage API - Stateless Flow Diagram 14
3 Cyber Security 16
3.1 CSOC Onboarding - Prerequisite Questionnaire for Internal Systems 16
3.2 Patient Triage API - Threat model 16
3.2.1 Solution 16
3.2.2 Scope 16
3.2.3 Assumptions 16
3.2.4 Exec Summary/High risk findings and recommendations 17
3.2.5 Data flows 17
3.2.6 Trust Boundaries 17
3.2.7 Entities 17
3.2.8 Data Assets 18
3.2.9 External Dependencies 18
3.2.10 Entry/Exit Points 19

3.2.11 Trust Levels 19
3.2.12 Managing threats 20
3.2.13 Threat Status 20
3.2.14 Threats 21
3.2.15 Validate & Verify 23
3.2.16 Actions 23
3.2.17 Success criteria 23
3.3 Penetration Test 23
3.3.1 Sequence of Events 24
3.3.2 Test Output details 24
3.3.3 Outstanding items 25
3.3.4 Meeting Notes 25
4 DOS Rest API - Test environment account for SAET_REST_WS 27
4.1 Context 27
4.2 Detailed technical info including authorization 27
4.3 API Account details to use 27
4.4 DOS related contacts who can help 28
4.5 Account details submitted for onboarding: 28
5 Interop standards team engagement 30
5.1 Meeting 08 May 2025 30
5.2 Meeting on 07/04/25 with Interop team 30
5.3 Triage API use cases 31
5.4 Related API use cases 32
5.5 Working assumptions 32
5.6 Use Case - Triage of patient by non-clinical staff via Triage API 33
5.6.1 Initiate triage 34
5.6.2 Triage loop 36
5.6.3 Triage outcome 37
5.7 Use case - Triage of patient by clinical staff via Triage API 38
6 Key Performance Indicators (KPIs) 40
6.1 Patient Triage API - Key Performance Indicators 40
6.1.1 Executive Summary 40

6.1.2 KPI Summary 40
6.1.3 KPI Notes 41
6.1.4 Monitoring and Reporting 42
6.1.5 Known Gaps 42
6.1.6 Source Documents 42
6.1.7 Suggested Actions 43
7 Non-Functional Requirements (NFRs) 44
7.1 Actions 53
7.2 NFR: Availability 54
7.2.1 Terminology 54
7.2.2 Background 54
7.2.3 Assumptions 54
7.2.4 Acceptance Criteria 55
7.3 NFR: Compatibility and Accessibility 57
7.3.1 Background 57
7.3.2 Assumptions 57
7.3.3 Acceptance Criteria 57
7.4 NFR: Compliance and Governance 57
7.4.1 Background 57
7.4.2 Assumptions 58
7.4.3 Acceptance Criteria 58
7.5 NFR: FinOps 59
7.5.1 Provisional content 60
7.5.2 Assumptions 60
7.5.3 Acceptance Criteria 60
7.5.4 Task Priority Breakdown 62
7.6 NFR: Interoperability 62
7.6.1 Background 62
7.6.2 Assumptions 62
7.6.3 Acceptance Criteria 62
7.7 NFR: Observability, Monitoring, Metrics, Dashboards and Alerting 64
7.7.1 Background 64

7.7.2 Assumptions 64
7.7.3 Acceptance Criteria 64
7.8 NFR: Performance 69
7.8.1 2. Scope 69
7.8.2 3. Performance Objectives Summary 70
7.8.3 4. Response Time Requirements 70
7.8.4 5. Throughput & Load Requirements 70
7.8.5 6. Scalability Requirements 71
7.8.6 7. Reliability Under Load 71
7.8.7 8. Performance Testing Requirements 71
7.8.8 9. Monitoring & Observability Requirements 72
7.8.9 10. SLAs, SLOs & SLIs 72
7.8.10 11. Risks & Assumptions 73
7.9 NFR: Production and Path To Live environments 73
7.9.1 Assumptions 73
7.9.2 Acceptance Criteria 73
7.10 NFR: Reliability and Resilience 76
7.10.1 Background 76
7.10.2 Assumptions 77
7.10.3 Acceptance Criteria 77
7.11 NFR: Reproducibility 80
7.12 NFR: Scalability 81
7.12.1 1.Background 81
7.12.2 2. Scope 81
7.12.3 3. Scalability Objectives Summary 81
7.12.4 4. AWS Scalability Requirements 82
7.12.5 5. Defined Scalability Requirements 83
7.12.6 6. Monitoring & Observability Requirements 84
7.12.7 7. Scalability Testing Requirements 84
7.12.8 8. Risks & Assumptions 84
7.13 NFR: Security 85
7.13.1 Background 85

7.13.2 Assumptions 86
7.13.3 Acceptance Criteria 86
7.14 NFR: Sustainability 91
7.15 NFR: Version Control and Release Management 91
7.15.1 Version control 91
7.15.2 Parallel Versioning 93
7.15.3 Deployment Management 93
7.15.4 CI CD Deployment 94
7.15.5 Release Management 94
7.15.6 Patch Management 95
7.15.7 Hot Fix Release 95
7.15.8 Date Time Configuration 95
7.15.9 Seasonal Time Adjustments 95
7.15.10 Verification of Code Quality 95
7.15.11 Backups and Rollbacks 96
8 Patient Triage API Architecture C4 Model 97
8.1 System Context 97
8.2 Container Diagram 97
8.3 Notes 97
9 Solution Architecture Framework Review October 2025 98
9.1 Context 98
9.2 Assessment Summary 98
9.3 Actions 99
10 Triage API Infrastructure 107
10.1 Triage API - Multi-AZ 107
10.2 Triage API - Multi-Region 108

1 Aggregated /_status Health Check – Design

Status	**Draft**
Created	**2026-08-07**
Owner	Richard Beggs
Reviewed by	



This page describes the design for an aggregated `/_status` health check endpoint for the Patient Triage API.
The goal is to ensure that a single health check reflects the liveness of **all** deployed API versions, not just one.

1.1 1. Background and Problem Statement

The Patient Triage API supports multiple concurrent versions, each backed by a separate AWS Lambda function and routed via an `Accept: application/fhir+json; version=N` header. Requests are dispatched by API Gateway routing rules to the appropriate stage (`v1` or `v2`).

The existing `/_status` endpoint is used as a health check by the NHS APIM proxy layer (configured in `x-nhsd-apim.yaml`). However, it has a significant blind spot:



Current behaviour

`/_status` is hardcoded to route to the **v1 stage only** via a single routing rule in API Gateway. A broken `v2` Lambda deployment will **not** cause the health check to fail.

1.1.1 Routing rules today

Rule name	Condition	Target stage	Priority
`triage_v1`	`Accept` header matches `*version=1`	v1	1

Rule name	Condition	Target stage	Priority
`triage_v2`	`Accept` header matches `*version=2`	v2	2
`triage_status_v1`	Base path matches `_status`	**v1 only**	3

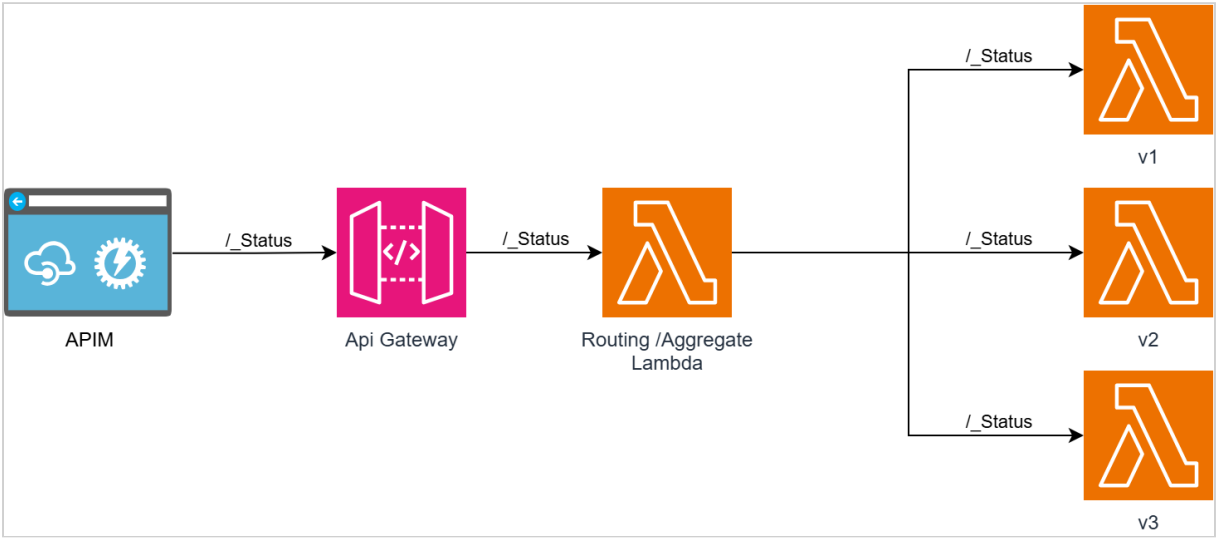
Introduce a **Status Aggregator Lambda** that sits in front of the */status API Gateway integration. When invoked, it probes _all* deployed triage Lambda versions in parallel using the AWS Lambda SDK, aggregates the results, and returns a single health status.

Key principle

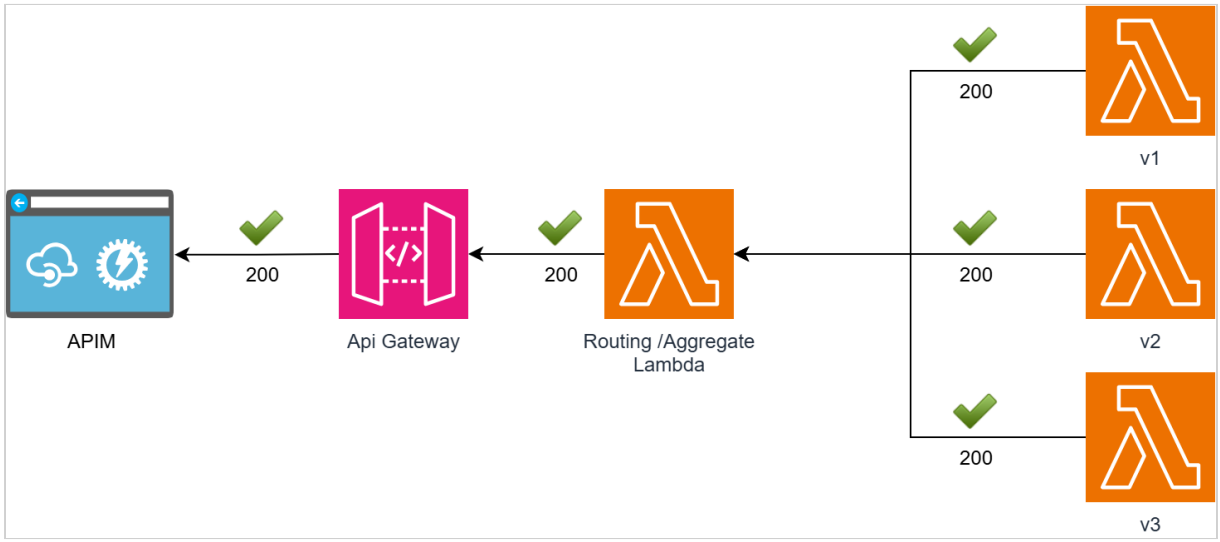
Rather than routing to one version, the aggregator invokes all versions directly via the Lambda — no HTTP round-trip, no extra routing rules required. Adding a new version in future only requires updating one environment variable.

1.2 3. Architecture Diagram

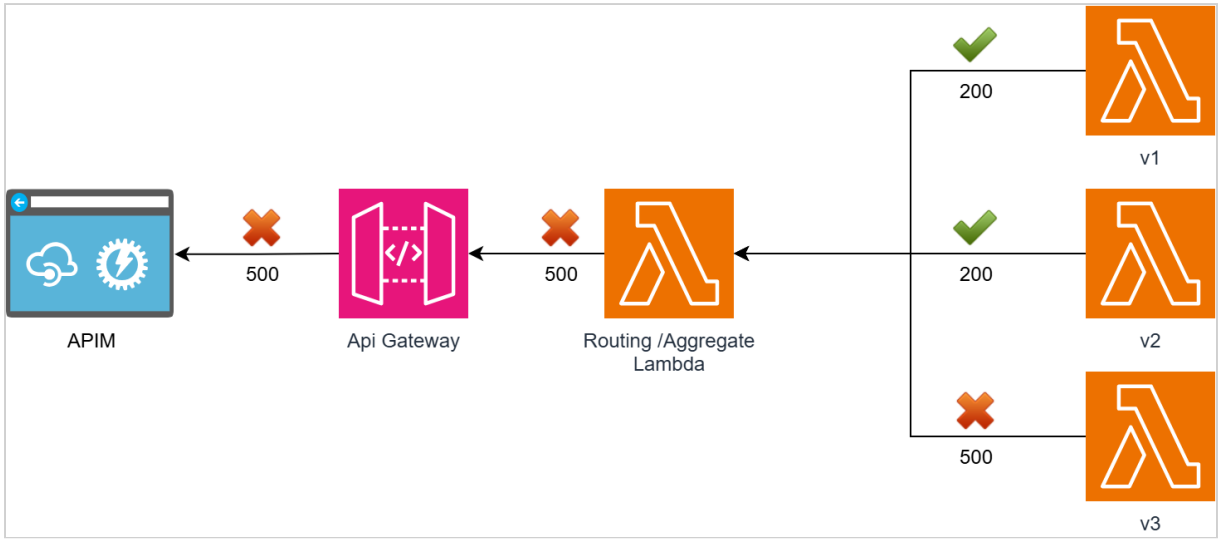
1.3 /_status Request



1.4 Successful Response



1.5 Unsuccessful Response



1.6 4. Component Design

1.6.1 4.2 Health check logic

The probe payload sent to each triage Lambda is identical to the synthetic request used by the existing `/_status` integration: a FHIR `TaskRequest` with `INVALID SKILLSET`. This deliberately triggers a FHIR `OperationOutcome` error response, which confirms the Lambda is alive and handling requests without requiring valid clinical data.

Outcome from downstream Lambda	Interpretation	Aggregated result
Any valid response (including FHIR 4xx errors)	✅ **Healthy** — Lambda is alive	Counts as pass
`FunctionError` in response (unhandled exception)	❌ **Unhealthy**	Counts as fail
Lambda SDK exception (throttle, timeout, network)	❌ **Unhealthy**	Counts as fail

1.6.2 4.3 Aggregated HTTP response

Condition	HTTP status	Body
All versions healthy	✅ **200 OK**	{"message": "ok", "versions": {"<arn>": {"healthy": true, "detail": "ok"}, ...}}
One or more versions unhealthy	❌ **503 Service Unavailable**	{"message": "one or more versions unhealthy", "versions": {"<arn>": {"healthy": false, "detail": "FunctionError: Unhandled"}, ...}}

1.7 5. Decision: Lambda vs Step Functions

Concern	Lambda	Step Functions
Latency	✅ Parallel invocations in a single execution (~ms overhead)	⚠️ State transitions add 100–200 ms per step
Cost	✅ One Lambda invocation per health check	⚠️ Charged per state transition — higher cost for a frequent health check
Complexity	✅ ~60 lines of Python	❌ State machine definition + IAM + Lambda integration
Parallelism	✅ `ThreadPoolExecutor` fans out simultaneously	✅ `Parallel` or `Map` state also fans out
Failure aggregation	✅ Simple `all(healthy)` in Python	⚠️ `Catch` / `ResultSelector` JSON configuration
Execution history / audit	⚠️ CloudWatch logs only	✅ Full step-by-step execution history in console

Concern	Lambda	Step Functions
Per-version retry with backoff	⚠️ Requires custom retry logic in Python	✅ Built-in retry/backoff per state

Decision: Lambda. The Step Functions overhead (latency, cost, complexity) is not justified for a health check endpoint. Step Functions would become the better choice if per-version retry-with-backoff or a detailed audit trail of health check history were required.

1.8 6. Extensibility

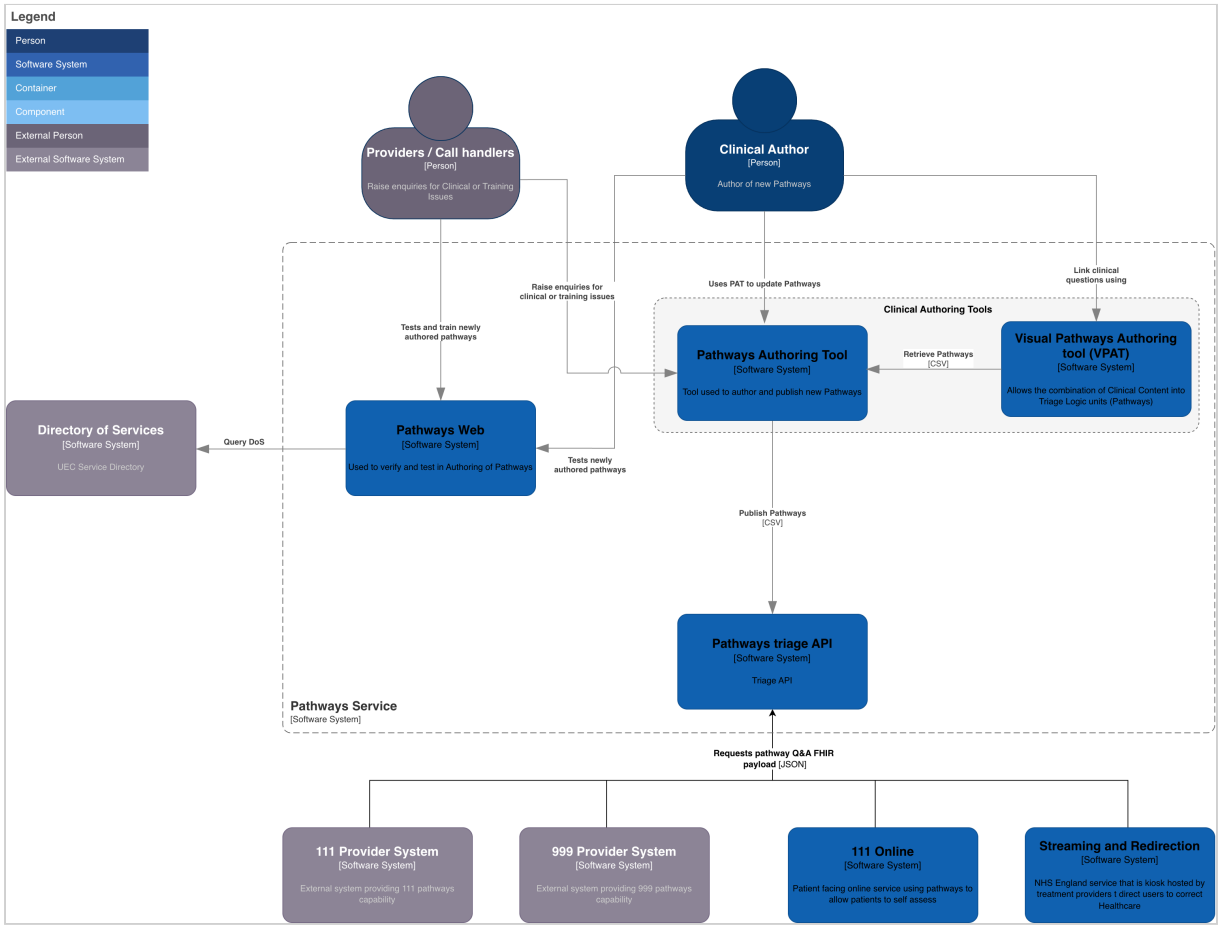
During the deployment process we will be looking to cerate a new environment variable TRIAGE_LAMBDA_ARNS. This will be populated with a comma separated list of the ARNs for all the lambda versions. This will be used by the aggerate lambda so it can loop around the ARN numbers for the and target all the versions. This would mean that we would not have to make changes to the aggregate lambda every time there is a new version released.

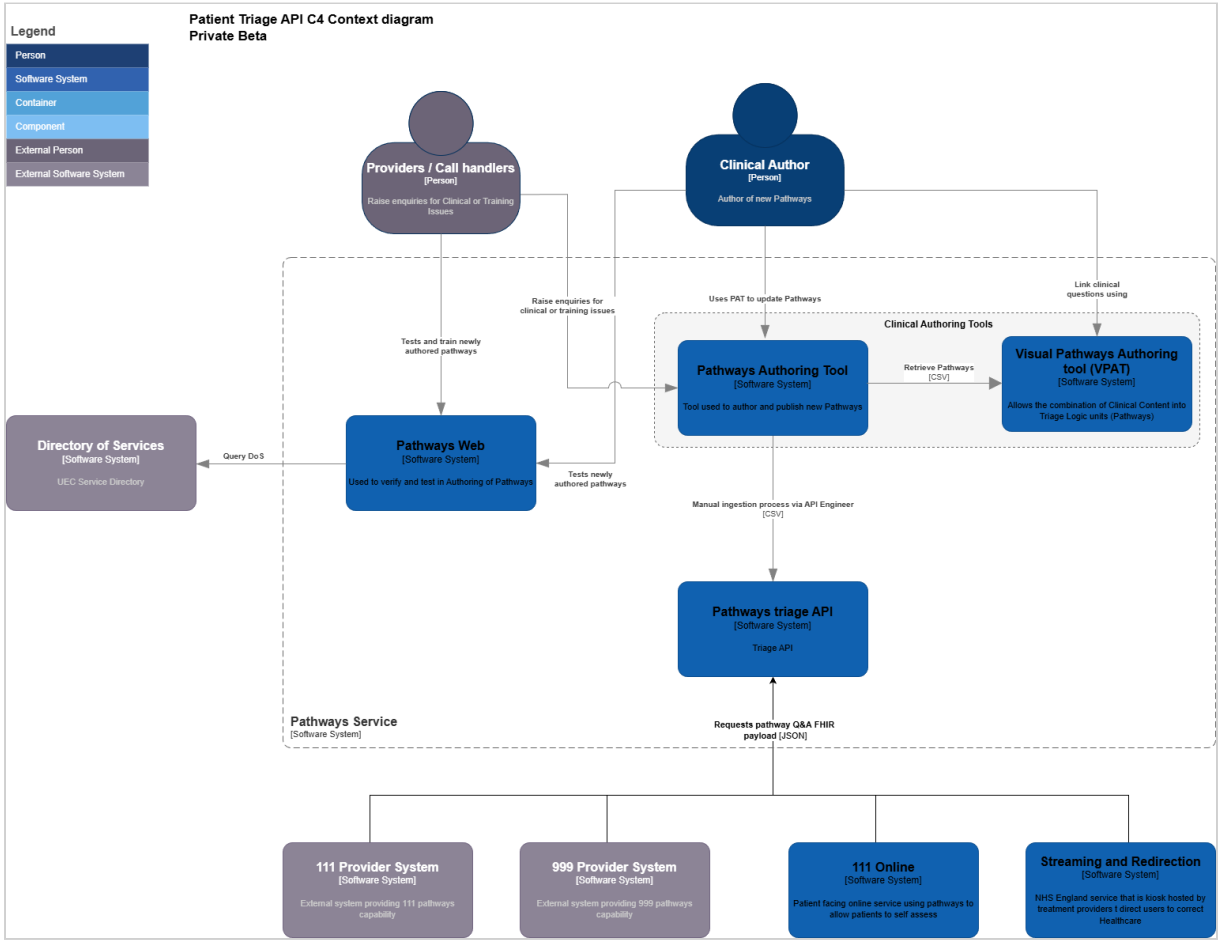
2 API High Level Design

2.1 Triage API

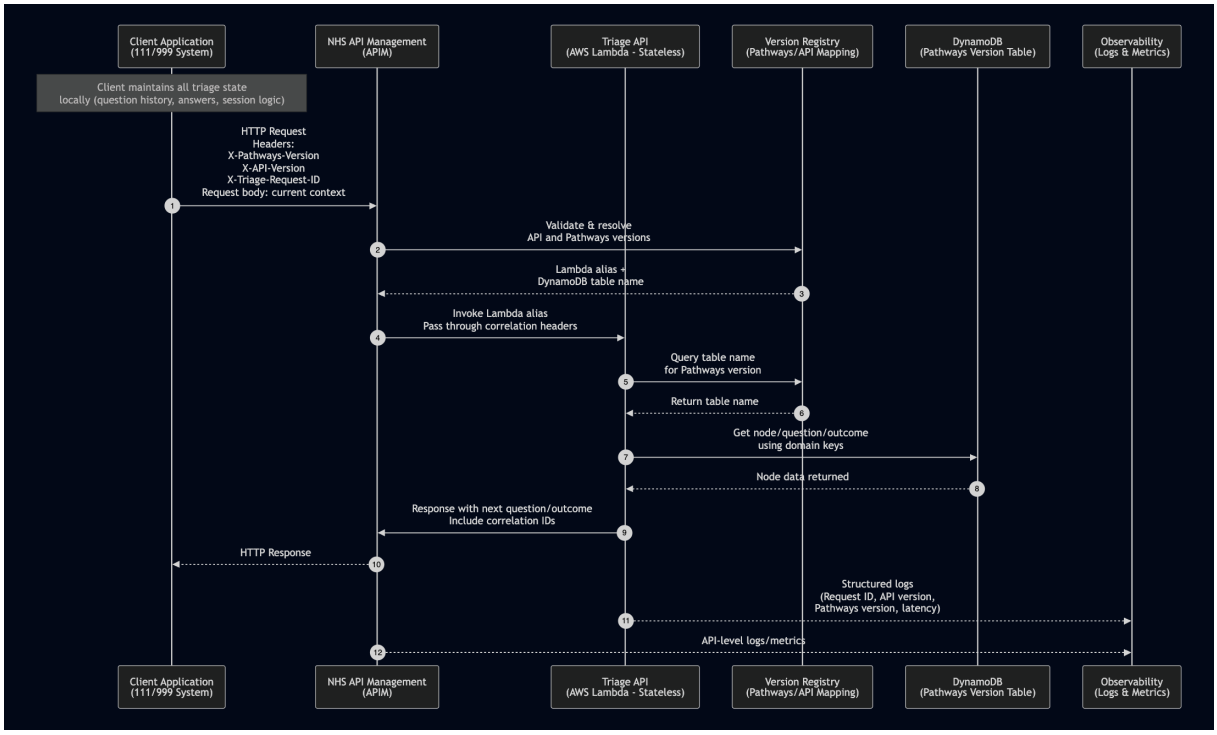
- Triage API - C4 Diagrams (see page 12)
- Triage API - Stateless Flow Diagram (see page 14)

2.1.1 Triage API - C4 Diagrams




Legend
Person
Software System
Container
Component
External Person
External Software System
Patient Triage API C4 Context diagram
Private Beta
Providers / Call handlers
[Person]
Raise enquiries for Clinical or Training Issues
Clinical Author
[Person]
Author of new Pathways
Raise enquiries for clinical or training issues
Uses PAT to update Pathways
Link clinical questions using
Clinical Authoring Tools
Tests and train newly authored pathways
Pathways Authoring Tool
[Software System]
Tool used to author and publish new Pathways
Retrieve Pathways
[CSV]
Visual Pathways Authoring tool (VPAT)
[Software System]
Allows the combination of Clinical Content into Triage Logic units (Pathways)
Directory of Services
[Software System]
UEC Service Directory
Query DoS
Pathways Web
[Software System]
Used to verify and test in Authoring of Pathways
Tests newly authored pathways
Manual ingestion process via API Engineer
[CSV]
Pathways triage API
[Software System]
Triage API
Pathways Service
[Software System]
Requests pathway Q&A FHIR payload [JSON]
111 Provider System
[Software System]
External system providing 111 pathways capability
999 Provider System
[Software System]
External system providing 999 pathways capability
111 Online
[Software System]
Patient facing online service using pathways to allow patients to self assess
Streaming and Redirection
[Software System]
NHS England service that is kiosk hosted by treatment providers t direct users to correct Healthcare

2.1.2 Triage API - Stateless Flow Diagram




```
sequenceDiagram
    autonumber

    participant Client as Client Application<br/>(111/999 System)
    participant APIM as NHS API Management<br/>(APIM - pass-through)
    participant Lambda as Triage API<br/>(AWS Lambda - Stateless)
    participant Registry as Version Registry<br/>(API & Pathways Mapping)
    participant Dynamo as DynamoDB<br/>(Pathways Version Table)
    participant Obs as Observability<br/>(Logs & Metrics)

    Note over Client: Client maintains all triage state<br/>locally (question history,
answers, session context)

    Client->>APIM: HTTP Request<br/>Headers:<br/>X-Pathways-Version<br/>X-API-
Version<br/>X-Triage-Request-ID<br/>Body: current context
    Note over APIM: APIM performs authentication,<br/>basic policy checks and
forwarding only<br/>(no version validation or routing logic)

    APIM->>Lambda: Invoke Triage API<br/>Forward headers unchanged
```

```
    Lambda->>Registry: Validate versions and resolve routing<br/>Inputs: X-API-Version,
X-Pathways-Version
    Registry-->>Lambda: Lambda behaviour/routing rules<br/>+ DynamoDB table name<br/
>(or error if invalid/incompatible)

    Lambda->>Dynamo: Get node/question/outcome<br/>from resolved Pathways table
    Dynamo-->>Lambda: Node data returned

    Lambda->>APIM: Response with next question/outcome<br/>Include correlation IDs
    APIM-->>Client: HTTP Response

    Lambda-->>Obs: Structured logs<br/>(Request ID, API version,<br/>Pathways version,
table name, latency)
    APIM-->>Obs: API-level logs/metrics
```

3 Cyber Security

3.1 CSOC Onboarding - Prerequisite Questionnaire for Internal Systems

The following questionnaire must be completed:

CSOC Onboarding initial questionnaire v2.0 (2024) - Patient Triage API.docx[1]

3.2 Patient Triage API - Threat model

How to use:

- **This is a standard template that has been designed to help you create a Threat model using STRIDE.**
- **Familiarise yourself with the content and review the worked example.**
- **Once familiar complete the sections and remove the section descriptions and red text.**

Please remember to delete this note from your final document.

3.2.1 Solution

Description and overview of the whole end-to-end process

3.2.2 Scope

In-scope

??

Out of scope

??

3.2.3 Assumptions

This section should contain assumptions that can be checked or challenged in the future as the threat landscape changes

1. https://nhs.sharepoint.com/:w:/r/sites/msteams_9646b6/Shared%20Documents/General/01%20Team%20Griffin%20Workstreams/Improving%20how%20we%20Connect%20-%20Patient%20Triage%20API%20Beta%20phase/Service%20Design%20and%20Transition/CSOC/CSOC%20Onboarding%20initial%20questionnaire%20v2.0%20(2024)%20-%20Patient%20Triage%20API.docx?d=wa36cfae557ff47bcbca9a14dafeb623c&csf=1&web=1&e=t2asQ5

Assumption	Impact if wrong (if not obvious)	Who to talk to (if known)	Who's following up	Follow up date

3.2.4 Exec Summary/High risk findings and recommendations

This section should contain an exec summary and list the high-level threats with provide recommendations. This can help form the unacceptable outcomes from a business perspective.

Threat findings should be written as follows:

*There is a risk that <**source**> due to <**event**> which could lead to <**consequence**>.*

-

Recommendations

3.2.5 Data flows

*If data flows are not represented in the architecture diagram under the solution section, then a diagram should be included here with dataflow overlay. The overlay doesn't have to be low level, just enough to get a sense of data paths and touchpoints to find threats at dataflow **origin** and **destination**, and the protocols used.*

3.2.6 Trust Boundaries

If trust boundaries are not represented in the architecture diagram under the solution section, then a diagram should be included here with trust boundaries marked.

3.2.7 Entities

This section should contain a table with all the relevant entities with a description

Entity	**Description**
Validate and forward?	
Process outputs?	
audit	

3.2.8 Data Assets

This section should contain a table with details about data assets in relation to the "Subject" of the threat model, what type of data is being processed, stored, or traverses any part of the model.

Data Asset	Description

3.2.9 External Dependencies

This section should contain a detail on external dependencies. These are items external to the application that may pose a threat to the application. These items are typically still within the control of the organization, but possibly not within the control of the development team. The first area to consider when investigating external dependencies is the production environment and requirements.

ID	Description
ID01	
ID02	
ID03	
ID04	
ID05	

3.2.10 Entry/Exit Points

This section should contain detail about entry points in relation to the "Subject" of the threat model. These are interfaces that attackers can interact with the application. Entry points in an application can be layered, an application may contain multiple entry points.

Entry points show where data enters the system (i.e. input fields, methods) and exit points are where it leaves the system (i.e. dynamic output, methods), respectively. Entry and exit points define a trust boundary

Name/Point	Description	Trust Level

3.2.11 Trust Levels

This section should contain detail on trust levels, this represents the access levels/rights that the application grants to external entities. This can be used to define the access rights or privileges required at each entry point, and those required to interact with each asset.

Entity	Description
Dev team?	
ITOC/Tech Ops?	
AWS Admins?	
CSOC?	
End User?	

3.2.12 Managing threats

Threat	Description & Rationale	Action
HIGH	Threat directly leads to a high risk event that leads to a compromise of system CIA or has direct reputational impact.	Mitigation must be implemented unless an exception is granted by NHSD Security and/or UKHSA equivalent.
MEDIUM	Threat indirectly leads to an Unacceptable Outcome or violation of our Core Values e.g., it relies on a sequence of threats or in combination with other factors external to the technical delivery could lead to an Unacceptable Outcome. Also, applicable if the control identified is defined in our Overarching Security Principles.	Identified controls must be added to a backlog and managed alongside functional changes i.e., a Jira ticket must be raised, and a record maintained of all decisions relating to the timing of implementation. Risks associated with these threats must be reported and within appetite.
LOW	All other threats	Identified controls must be added to the backlog and impact assessed i.e., a Jira ticket must be raised, and a record maintained of any decisions regarding the timing of any implementation or rejection (if appropriate). Risks associated with these threats must be reported.

3.2.13 Threat Status

This section is the main body of the document. This section should contain details of all potential threats to the system, each threat should be assigned a priority, a mitigation and a status recorded against it.

1. **Non mitigated threats**: Threats which have no countermeasures and represent vulnerabilities that can be fully exploited and cause an impact.
2. **Partially mitigated threats:** Threats partially mitigated by one or more countermeasures and can only partially be exploited to cause a limited impact.
3. **Fully mitigated threats**: These threats have appropriate countermeasures in place and do not expose vulnerabilities.

The model methodology is based on **STRIDE** as mentioned previously. The following subheadings should be included:

3.2.14 Threats

3.2.14.1 Spoofing – Authentication

Asset/Data flow	Threat	Priority	Mitigation	Status	Timescale to address/Ticket

3.2.14.2 Tampering – Integrity

Asset/Data flow	Threat	Priority	Mitigation	Status	Timescale to address/Ticket
Embedding of malicious code in repo					
Introduction of damaging or disruptive software/ packages i.e. supply chain poisoning. Insecure or unsupported packages.					
Wilful damage to data					
Wilful damage to system					

3.2.14.3 Repudiation - Non-repudiation / Privacy

Asset/Data flow	Threat	Priority	Mitigation	Status	Timescale to address/ Ticket
Deleting a file without due reason, but then denying it					
Changing records					
Changing scheduling					

3.2.14.4 Information Disclosure – Confidentiality

Asset/Data flow	Threat	Priority	Mitigation	Status	Timescale to address/ Ticket
Interception of information					
Not encrypting things at rest on AWS (could be viewed)					
Theft by insiders/outsiders					

3.2.14.5 Denial of Service – Availability

Asset/Data flow	Threat	Priority	Mitigation	Status	Timescale to address/Ticket

3.2.14.6 Elevation of Privilege – Authorisation

Asset/Data flow	Threat	Priority	Mitigation	Status	Timescale to address/Ticket

3.2.15 Validate & Verify

This section should highlight ways of validating the model and threats, and verification of success of actions taken

- *Have we written down or filed a bug for each threat?*
- *Is there a proposed/planned/implemented way to address each threat?*
- *Do we have a test case per threat?*

3.2.16 Actions

This section should contain a list of actions with a description and owner. This can be presented as a bulleted list of in a table.

Action	Description	Owner	Priority

3.2.17 Success criteria

- *You have raised Jira tickets/bug tickets against identified threats.*
- *You have a diagram or diagrams that everyone agrees represents the system or subject you are modelling.*

3.3 Penetration Test

Pen test is scheduled for week commencing 13th April 2026. This is a prerequisite for Private Beta go-live.

Company performing pen test: Dionach

Company	Dionach	https://www.dionach.com/services/assurance/penetration-testing/
Account Manager	Kelsey Smith	kelsey.smith@dionach.com[2]
Key Contact	James Simmons	james.simmons@dionach.com[3]

2. mailto:kelsey.smith@dionach.com
3. mailto:james.simmons@dionach.com

Test Consultant	Dionach	No longer planned for this work. ~~Karen Greer~~ ~~Short Code: KAGR8 (KAGR8@hscic.gov.uk[4])~~ ~~NHS Mail: karen.greer2@nhs.net[5]~~
Test Consultant	Dionach	Phill Campbell Short code: PHCA10 (PHCA10@hscic.gov.uk[6]) NHS Mail: phill.campbell4@nhs.net[7]

3.3.1 Sequence of Events

#	Step	Status	Details
1	**Kick-off call**	DONE	Scope agreed with Dionach
2	**Work Order Approval**	DONE	Work order received 11 Mar 2026
3	**Detailed Test Planning**	DONE	
4	**Final Prep Call**	DONE	Completed 02 Apr 2026
5	**Pen Test Execution**	IN PROGRESS	Started 13 Apr 2026
6	**Pen Test Report**	TO DO	

3.3.2 Test Output details

- Will update once we have more substantial feedback from the tester

- Ticket relating to sandbox issue: NPT-1218[8] - Fix Sandbox vulnerability DONE

4. mailto:KAGR8@hscic.gov.uk
5. mailto:karen.greer2@nhs.net
6. mailto:PHCA10@hscic.gov.uk
7. mailto:phill.campbell4@nhs.net
8. https://nhsd-jira.digital.nhs.uk/browse/NPT-1218?src=confmacro

3.3.3 Outstanding items

Requirements for the Pen test prep call. Red items need actioning or confirming, other items assumed ok:

Patient Triage API Penetration Test Requirements - done

- ~~Confirmation of the test API URLs - To do, handle via email ahead of the test date. Dependency on APIM prod certificates being sorted, otherwise fall back to Ref environment. Tester ok to wait for this.~~
- ~~Suitable network access to all API endpoints (via IP allowlisting)~~
- ~~API authentication tokens, credentials or certificates for authenticating with the APIs in scope - To do alongside above.~~
- ~~API documentation to be provided (Swagger Docs or Postman Collection)~~ -
- ~~Sample data for the completion of API requests -~~ Mentioned in prep call these are available in <repo>/tests/integration

AWS Technical Security Review Requirements - done

- ~~A single AWS user account with SecurityAudit and ReadOnlyAccess policies attached~~
  - ~~This role needs setting up in the AWS SSO Repo so we can assign the test consultant user accounts~~
  - ~~This repo: https://github.com/NHSDigital/aws-prod-sso-config~~
- ~~AWS CLI access keys - get this automatically once logging in via the aws link (https://d-9c67018f89.awsapps.com/start/)~~
- ~~Any updated documentation or HLDs of the AWS environment (if possible)~~

Secure Codebase Review Requirements - done

- ~~Access to the source code repository - public~~
- ~~Associated documentation for the codebase in scope. Nothing specific has been requested.~~
- ~~Access to a developer related to the codebase for the duration of the engagement - Andrew Walker, architects and other team members will be available if needed.~~
  - This is only needed if there is a suspected vulnerability and needs to talk through understanding

3.3.4 Meeting Notes

3.3.4.1 Final prep call 2nd April 2026

- Testing date confirmed start from **13th April**
- Finish and report finalised by **27th April**
- Additional internal QA period for ~ 5 days. **Output report due by 1st May**
- We will be notified of any high/critical issues discovered during the test (to begin remediation if needed) and a check-in summary towards the end of the testing period

- An email chain of progress will be used in lieu of a daily standup with the tester

3.3.4.2 Scoping call 5th March 2026

The pen test will focus on three primary areas:

1. The Patient Triage API (plus the Pathways Uploader)
2. AWS Security Review
3. Source Code Review

- Dionach will create a work order in the next couple of days which will be sent to the Pathways team for approval
- Once work order is approved a follow up call will be scheduled with test consultants for lower level detail planning
- A final prep meeting will be schedule 1 week before the pen test takes place
- 2x test consultants have been assigned by Dionach to this pen test and can work in parallel
- Non-formalised estimates for the testing:
  - API pen test ~3 days
  - AWS security review ~4-5 days
  - Source code review ~5 days
- The source code review will focus high level primarily on outdated libraries, exposed secrets etc and is a time boxed activity

4 DOS Rest API - Test environment account for SAET_REST_WS

4.1 Context

We are currently completing an alpha build of the pathways triage api for early November 2025.

We require a test DOS endpoint we can call manually or automatically to prove that the outputs from the triage engine we have developed are correct and compatible with the DOS.

The DOS has a few different endpoints (SOAP, Rest, Future DOS), this is for the DOS Rest API and specifically we need to use the **get service details by clinical term** (Sg,sd,dx) and get some services back.

Details are here: https://digital.nhs.uk/developer/api-catalogue/directory-of-services-urgent-and-emergency-care-rest#get-/services/byClinicalTerm/-caseId-/-postcode-/-searchDistance-/-gppracticeId-/-age-/-gender-/-disposition-/-symptomGroupDiscriminatorCombos-/-numberPerType-

As per the above page, endpoint looks to be listed here:

https://digital.nhs.uk/developer/api-catalogue/directory-of-services-urgent-and-emergency-care-rest#overview--environments-and-testing

The account was requested for UAT1 so the URL may be prefixed e.g.

https://uat1.directoryofservices.nhs.uk/app/controllers/api

Suggest contact DOS technical colleague for more info.

4.2 Detailed technical info including authorization

- https://github.com/nhsd-a2si/docs-dos-api/blob/master/_pages/rest_api/rest_api_authentication.md
- https://github.com/nhsd-a2si/docs-dos-api/blob/master/_pages/rest_api/byClinicalTerm.md

4.3 API Account details to use

Username:

SAET_REST_WS

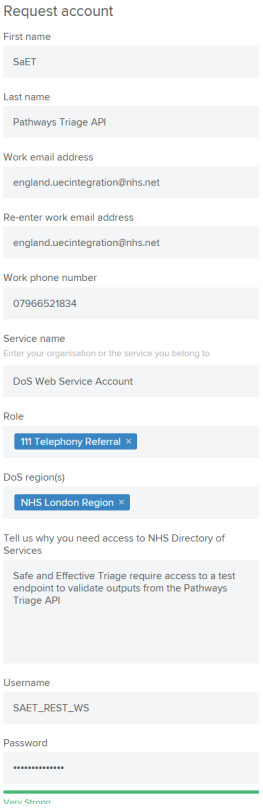
Password:

Ask Afzal, Tharack, Andrew Walker, Gareth Nelson.

4.4 DOS related contacts who can help

- Jonathan Pearce - DOS Tech lead
- Peter van der merwe - DOS Architect
- Katherine O'Doherty - Lead Product Manager
- Oliver Lewis - Senior Delivery Manager
- Alex Langley - NHS Senior Architect

4.5 Account details submitted for onboarding:



Some DOS internal guidance on what to fill out for onboarding: STAGE 2.7 Access to the DoS REST API Testing environment guidance (see page 27)

The account had to be provisioned with an email address so to prevent a clash with my personal email i have used the shared mailbox - england.uecintegration@nhs.net[9]. There shouldn't be any need to access this unless you require a password reset. Please contact Afzal Mufti, Zohara Ali, Maggie Herbert if you need something from this mailbox.

9. mailto:england.uecintegration@nhs.net

There is no expiry date on the account although the DOS team have been advised that this is needed only for November 2025 (to support the alpha poc). There is a chance it could be routinely removed after this date without us requesting extending. DOS page tracking accounts[10].

10. https://nhsd-confluence.digital.nhs.uk/spaces/DOSIS/pages/913227764/IS+Users+by+software+provider+and+API

5 Interop standards team engagement

This is Informal holding area for artifacts and resources shared with or by the interoperability standards team.

5.1 Meeting 08 May 2025

Today met with Keith Emmerson (Senior PM) and Kevin Sprague (Senior interop architect). Afzal and Tharack representing team Griffin.
Summary below:

Set context

- We restated the engagement aims and ambitions for the Triage API
- Ran through one of the the key use cases (triage via non-clinical staff member).
- Briefly outlined the proposed key api interactions (set context, request next activity, Q&A loop, triage outcome)
- Stated we are entering a design phase this next sprint with a view to begin work on a technical POC the following sprint
- Requested steer and modelling support for the design of the Triage API.

Interop team support

- Interop team agreed this is a valid use case and something they would like to support.
- Interop team are resource constrained so would struggle to release someone from existing commitments for detailed modelling work.
- We proposed a weekly / fortnightly protected slot with a named modeller available to consult with, ask queries and share current progress with.
- Interop team supportive of the proposal and will put this to their Monday leadership team call where they triage new work requests and recommend support.

Actions

- Interop team take proposal to team meeting and report back
- Griffin team to share back initial API draft or design progress by the end of next sprint
- Griffin team to share any relevant show and tell invites or other meetings to keep interop team in the loop with how this progresses.

5.2 Meeting on 07/04/25 with Interop team

Eleanor Bredin, Dan Parker, David Barnet, Kevin Sprague.
Gave overview of Pathways transformation work and the support we require.

- DOS Implementation guide[11]

11. https://simplifier.net/guide/Directory-of-Service/Home?version=current

- BaRS Implementation guide[12]

5.3 Triage API use cases

Use case	Considerations	API impact
Self-triage – e.g. individuals using automated online triage tools	• Unguided support / simple UI • No / limited override • May be anonymous • May be more cautious? (clinically) • Lower / different audit requirements	• Different access mode / endpoint? • May be limited opportunity for personalisation unless logged in via NHS app • May be less verbose than other settings
Triage of patient by non-clinical staff (see page 33) – e.g. non-clinical call handlers performing telephone triage supported by an automated triage tool	• Guided support with scripted questions, inc additional clarifying statements • Audit every interaction • Interim care advice • Interim dispositions (e.g. CAT2 ambulance) • Can go back and override questions? (confirm) • May support a UI or API only interface	• additional meta data for audit trail / reporting • api will need to deliver triage outcome model info (that can search the DOS)
Triage of patient by clinical staff (see page 38) (Ambulance revalidation, clinical assessment service, Mod2, Paccs)	• Less reliance on structured triage Q&A, clinical staff have more freedom to probe and select what they think is correct ◦ Pathways Mod2 functionality (more freedom to edit and change answers) ◦ PaCCS • Can override original disposition	• Decide if this is in scope or how it fits in

12. https://simplifier.net/guide/nhsbookingandreferralstandard/Home/About-BaRS/Releases?version=1.8.2

Use case	Considerations	API impact
Continuation of triage from one access channel or care setting to another - for example between a health advisor and clinician	• Continuation of state or accurate evaluation of the previous state to pick up • Interop between previous care settings is essential • Could another service play a role here - e.g. RCS if encounter detail is saved there, it could be used as an input?	• Resume session or ideally all fits within initial patient context when starting triage
Personalisation of triage	• Context aware, adapt questions / pre-answer questions if input data is from a trusted source • A good use case for personalisation would be Repeat Caller Service. If a flag is found (e.g. RCS), then follow alternate escalation pathway. *Note RCS flag does not yet exist, in early discussions*.	
Group triage	Suggest out of scope for now	
Other use cases		

5.4 Related API use cases

- Directory Service lookup for suitable onward referral using a pathways triage outcome
- Creation and sharing of encounter reports - reports containing details of an individual's triage, either for informational purposes or to support subsequent care.
- Check for worsening patient - has the patient made multiple related contacts to UEC care settings

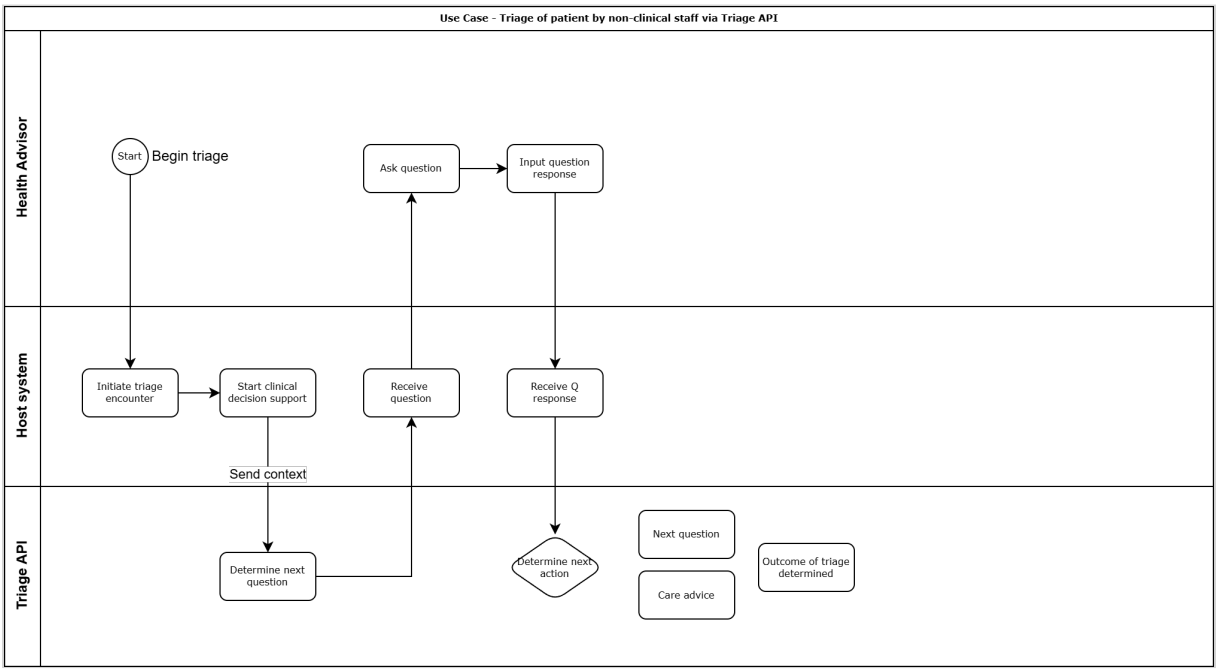
5.5 Working assumptions

- Restful API
- API hosting on APIM
- Api will be stateless
- Api will be idempotent
- Align to FHIR R4 and UK Core

5.6 Use Case - Triage of patient by non-clinical staff via Triage API

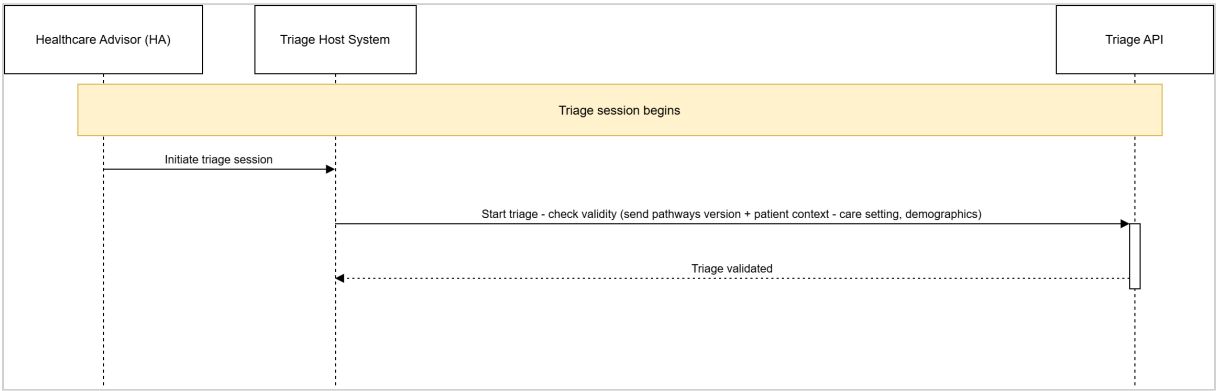
Use Case - Triage of patient by non-clinical staff via Triage API

User Story Summary (Clinical Overview)	As a Healthcare Advisor (HA) I can safely and effectively triage a patient using a triage tool So that I can provide them with appropriate care, advice, or onward referral based on their symptoms
Actors (Role)	Healthcare Advisor, Patient, System (Triage Host System / triage UI)
Frequency of Use	For every patient call to 111 requiring triage
Triggers	A patient contacts 111 with a health concern that requires triage or assessment
Pre Conditions	1. HA is logged into the triage system and authenticated. Is trained for an available version of the triage tool. 2. Patient or third party is engaged and able to provide symptom information 3. (optional) Patient demographics are established and patient traced to an NHS number
Post Conditions	1. An appropriate disposition / triage outcome is provided by the Triage API 2. Triage outcome is communicated to the patient / third party including care advice ~~or referral details~~ < this is separate from triage
Main Course	1. HA initiates a triage encounter with the patient via the triage host system 2. HA establishes chief complaint and inputs to triage tool 3. System presents triage questions to establish symptoms 4. HA records question responses in the triage tool 5. (optional) interim care advice is presented and communicated back to the caller 6. System provides a recommended care disposition and next activity time frame (e.g. emergency ambulance within 2 hours, primary care 48 hours, self-care) 7. HA delivers the triage outcome to the patient along with any care advice
Alternate Course	If symptoms change during the triage, HA may restart or branch the triage path to reassess If the patient cannot provide sufficient information, a non-clinical outcome may be advised (e.g. if the caller is under age or no longer with the patient) If it emerges the request does not require clinical triage alternate advice may be given e.g. call the police
Exception	The triage system is unavailable or experiences an error, HA may fall back to business continuity protocols e.g. manual paper based triage scripts or redirecting to a clinical supervisor



To create the sequence diagrams here, copy/paste the mermaid code to https://mermaid.live/edit to edit.
Once happy open a draw.io diagram and from the menu choose Arrange.. > Insert... > Advanced.. > Mermaid.
Paste in the code and it will be converted to a drawing.

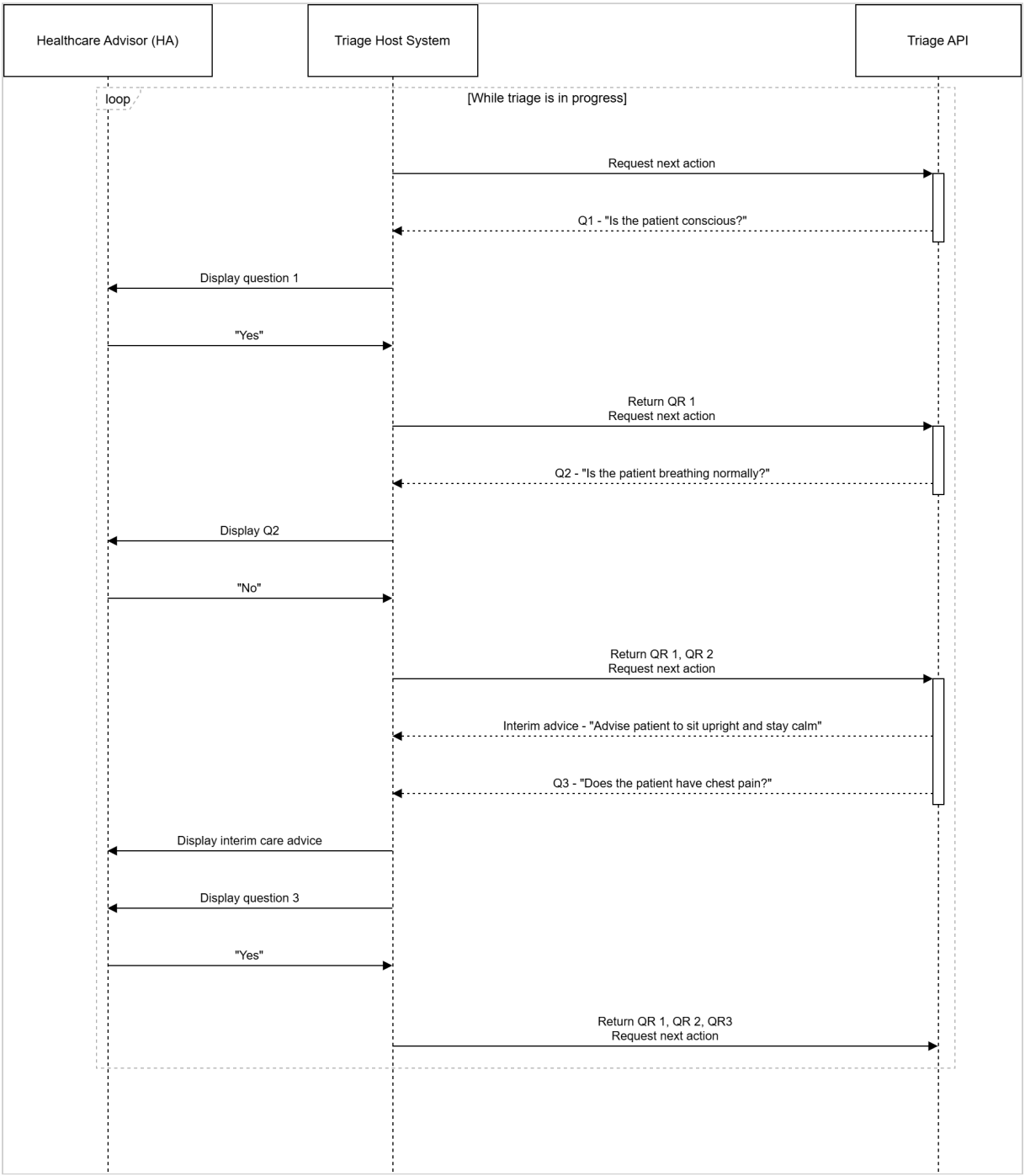
5.6.1 Initiate triage



https://mermaid.live/edit

```
sequenceDiagram
    participant HA as Healthcare Advisor (HA)
    participant Host as Triage Host System
    participant API as Triage API
    Note over HA, API: Triage session begins
    HA->>Host: Initiate triage session
    %% activate HA
    %% activate Host
    Host->>API: Start triage - check validity (send pathways version + patient context - care setting, demographics)
    activate API
    API-->>Host: Triage validated
    deactivate API
```

5.6.2 Triage loop



Click here to expand... mermaid

https://mermaid.live/edit

```
sequenceDiagram
participant HA as Healthcare Advisor (HA)
participant Host as Triage Host System
participant API as Triage API
```

```
loop While triage is in progress
Host->>API: Request next action
activate API
API-->>Host: Q1 - "Is the patient conscious?"
deactivate API
Host->>HA: Display question 1
HA->>Host: "Yes"


Host->>API: Return QR 1 <br> Request next action
activate API

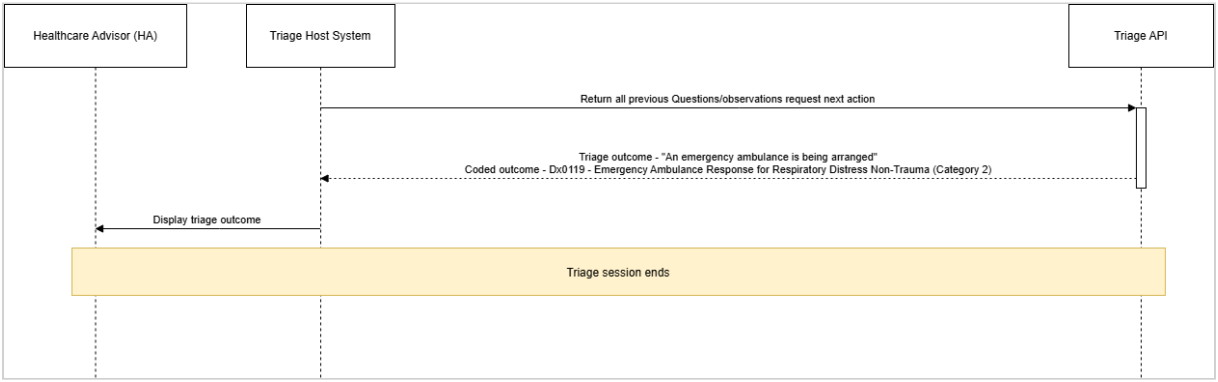
API-->>Host: Q2 - "Is the patient breathing normally?"
deactivate API
Host->>HA: Display Q2
HA->>Host: "No"
Host->>API: Return QR 1, QR 2 <br> Request next action
activate API

API-->>Host: Interim advice - "Advise patient to sit upright and stay calm"
API-->>Host: Q3 - "Does the patient have chest pain?"
deactivate API

Host->>HA: Display interim care advice
Host->>HA: Display question 3
HA->>Host: "Yes"
Host->>API: Return QR 1, QR 2, QR3 <br> Request next action
activate API


end
```

5.6.3 Triage outcome



Click here to expand mermaid code...

https://mermaid.live/edit

```
sequenceDiagram
    participant HA as Healthcare Advisor (HA)
    participant Host as Triage Host System
    participant API as Triage API
        Host->>API: Return all previous Questions/observations request next action
        activate API

        API-->>Host: Triage outcome - "An emergency ambulance is being arranged" <br> Coded outcome - Dx0119 - Emergency Ambulance Response for Respiratory Distress Non-Trauma (Category 2)
        deactivate API

        Host->>HA: Display triage outcome

    Note over HA, API: Triage session ends
```

5.7 Use case - Triage of patient by clinical staff via Triage API

Considering splitting this out as it is blurring the lines between triage continuation and a brand new triage by clinician

Use Case - Triage of patient by clinical staff via Triage API

User Story Summary (Clinical Overview)	As a Clinician (e.g. CAS clinician) I can review, amend, or continue a triage initiated by another user or channel, or initiate a new triage So that I can validate or override the triage outcome, ensuring clinically safe and appropriate decisions for the patient
Actors (Role)	Clinician, Patient, System (Triage Host System / triage UI)

User Story Summary (Clinical Overview)	As a Clinician (e.g. CAS clinician) I can review, amend, or continue a triage initiated by another user or channel, or initiate a new triage So that I can validate or override the triage outcome, ensuring clinically safe and appropriate decisions for the patient
Frequency of Use	For escalations or handoffs from non-clinical triage, or where clinical input is required due to complexity or acuity
Triggers	• Triage is escalated from a non-clinical user (e.g. 111 HA) to a clinical advisor • Patient directly accesses a clinical assessment service (e.g. 999 revalidation, clinical callback) • Clinical staff review or re-assess an existing triage
Pre Conditions	1. Clinician is logged into the triage system and authenticated 2. Full history of prior triage interaction (if applicable) is available 3. Patient or third party is engaged and able to provide updated symptom information 4. (optional) Patient demographics and NHS number are known
Post Conditions	1. A clinically validated triage outcome is recorded. This could be same, modified from, or overriding the previous recommendation 2. The triage outcome and any care/referral actions are communicated to the patient or care coordinator Separate from triage: Audit logging, Directory lookup, PEM
Main Course	1. Clinician accesses an existing, active triage or initiates a new triage encounter 2. System presents the final triage outcome or current triage question 3. Clinician reviews existing triage state or chief complaint 4. Clinician may restart the triage or resume (jump back) from a previous question 5. Clinician continues the triage by asking the patient questions 6. System generates a triage outcome 7. Clinician may override the final disposition with justification 8. Clinician communicates final outcome and care advice to patient or onward care service
Alternate Course	• Clinician identifies a more urgent or less urgent condition and adjusts triage accordingly • Clinician uses discretion to skip or modify standard triage flow • Outcome may be overridden based on clinical judgement and documented reasoning
Exception	• The triage system is unavailable or fails to load prior triage state; clinician may perform assessment using offline clinical tools or revert to manual documentation

6 Key Performance Indicators (KPIs)

6.1 Patient Triage API - Key Performance Indicators

6.1.1 Executive Summary

This page consolidates the measurable service targets defined across the current Non-Functional Requirements (NFR) documents for the Patient Triage API. It is intended to provide leadership and service owners with a single view of the core service commitments for availability, performance, recovery, reliability, and capacity.

The KPI set below includes only targets that are explicitly stated in the source NFRs. Items that are still incomplete or marked as TBD in the source documents are listed separately under Known Gaps.

6.1.2 KPI Summary

KPI	Target	Why it matters	Measurement / evidence	Source NFR
Service availability	99.90%	Confirms the service remains available for patient-facing use and aligns with the expected service resilience standard.	Service uptime measured against the API availability target.	NFR: Availability (see page 54)
Availability period	24x7	Confirms the service is expected to be available at all times, including during planned maintenance where possible.	Operational service hours.	NFR: Availability (see page 54)
Planned maintenance allowance	Maximum 150 minutes per month, with a maximum of 60 minutes for any single maintenance activity	Limits the operational impact of planned change.	Maintenance window tracking and change reporting.	NFR: Availability (see page 54)
Recovery Time Objective (RTO)	2 hours	Defines the maximum acceptable time to restore service after a major incident.	Disaster recovery and business continuity testing.	NFR: Availability (see page 54)
Recovery Point Objective (RPO)	Close to zero seconds	Minimises data loss in a recovery scenario.	Backup and recovery design validated against recovery objectives.	NFR: Availability (see page 54)

P95 response time for Triage POST endpoint	Less than 300 ms	Measures end-user responsiveness for the core triage transaction.	P95 latency monitoring and alerting for the Triage POST endpoint.	NFR: Performance (see page 69)
Overall error rate during peak load	Less than 0.1%	Confirms the service remains reliable under expected and peak demand.	Error-rate monitoring during peak load and performance testing.	NFR: Performance (see page 69)
5xx error rate under normal load	No more than 0.01%	Tracks severe platform or application failures under standard operating conditions.	5xx response monitoring under normal operating conditions.	NFR: Performance (see page 69)
Peak demand baseline	6.56 TPS	Establishes the current expected peak throughput based on observed demand.	Calculated from 2,147 sessions per busiest hour and average journey length.	NFR: Scalability (see page 81)
Load test / future-state capacity target	120 TPS	Demonstrates planned headroom for future growth and additional pathways.	Load testing at full production design target.	NFR: Scalability (see page 81)
Traffic resilience target	At least 2x normal traffic volume	Confirms the platform can absorb demand growth above the current baseline.	Load and scalability testing.	NFR: Scalability (see page 81)

6.1.3 KPI Notes

6.1.3.1 Performance and Reliability

- The primary response-time KPI is the P95 latency target of less than 300 ms for the Triage POST endpoint.
- The performance NFR also requires alerts when P95 latency exceeds 300 ms and states that latency, throughput, error rate, and autoscaling response time should be monitored as service level indicators.
- The scalability NFR includes a test statement that P95 latency should stay below 500 ms for peak-load scalability testing. This has been treated as a test threshold rather than the main service KPI because the explicit service target in the performance NFR is less than 300 ms.

6.1.3.2 Availability and Recovery

- The service is expected to operate 24 hours a day, 7 days a week.
- Planned maintenance is permitted, but the combined allowance must not exceed 150 minutes in a month, with no single activity exceeding 60 minutes.
- Recovery objectives are defined at service level: RTO of 2 hours and RPO close to zero seconds.

6.1.3.3 Capacity and Growth

- The current peak demand baseline is 6.56 TPS, derived from the busiest recorded hour of 2,147 sessions and the documented average journey length.
- The solution is expected to be load tested to 120 TPS to provide headroom for future demand.
- The service must handle at least double normal traffic volume.

6.1.4 Monitoring and Reporting

The NFRs state that KPI monitoring should be supported by:

- ODIN dashboards for latency, scaling events, saturation, and concurrency.
- Alerts for P95 latency greater than 300 ms, error rates, and saturation signals.
- AWS X-Ray for end-to-end latency analysis.
- Centralised logging in CloudWatch with export to NHS England observability platforms.

6.1.5 Known Gaps

The following items are referenced in the NFRs but do not yet have an agreed measurable target suitable for the KPI table above:

Item	Current position	Impact
Autoscaling response time	Defined as "N seconds (TBC)" in the scalability NFR	Prevents a committed scaling-speed KPI from being published
Cost KPI / budget threshold	FinOps defines governance and review cadence but no explicit cost target	No agreed financial KPI can be stated yet

6.1.6 Source Documents

- NFR: Performance (see page 69)
- NFR: Scalability (see page 81)
- NFR: Availability (see page 54)
- NFR: Reliability and Resilience (see page 76)

- NFR: Observability, Monitoring, Metrics, Dashboards and Alerting (see page 64)

6.1.7 Suggested Actions

1. Confirm the autoscaling response-time target so it can be promoted into the KPI set.
2. Confirm the planned maintenance window wording and whether it should appear on the final Confluence page.
3. Decide whether a formal cost KPI is required in addition to the current FinOps governance controls.
4. Assign an owner and review cadence for each KPI to support regular service reporting.

7 Non-Functional Requirements (NFRs)

This page contains the non-functional requirements for the Triage API. The linked sub-pages detail how each of the requirements will be met, and describe the requirements in more detail where required..

Area	Non-functional requirements	Source	AM Comments:
Security (see page 85)	The security approach in the solution shall comply with the Engineering Technical Authority Redlines[13]	Redlines[14]- Engineering Technical Authority Redlines	We need to conduct a red lines and SA Framework review on the proposed Alpha solution once fully defined and retest at each phase. Now done: Red Lines Assessment[15] SAF assessment also completed.
	The NHSE Approved Cryptographic Algorithms GPG v4.0[16] specification MUST be met by any approach to privacy and security based on encryption	NHSE Approved Cryptographic Algorithms GPG v4.0[17]	At this stage (Alpha design) we do not anticipate any secure hashing requirements as part of business flow. This standard is relevant for TLS/ SSL, Auth tokens (JWTs, APIM security), any encryption of data at rest.

13. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx?csf=1&web=1&e=8VJbnO&CID=dbbda7ae-6ca8-44af-a20c-0326c47991f4
14. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx?csf=1&web=1&e=8VJbnO&CID=dbbda7ae-6ca8-44af-a20c-0326c47991f4
15. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1320957881/Red+Lines+Assessment
16. https://nhsd-confluence.digital.nhs.uk/spaces/IMDD/pages/24094041/IMDD+-+Gitlab+DDC+Spine?preview=%2F24094041%2F24094043%2FApproved+Cryptographic+Algorithms+GPG+v4.0.pdf
17. https://nhsd-confluence.digital.nhs.uk/spaces/IMDD/pages/24094041/IMDD+-+Gitlab+DDC+Spine?preview=%2F24094041%2F24094043%2FApproved+Cryptographic+Algorithms+GPG+v4.0.pdf

Area	Non-functional requirements	Source	AM Comments:
	The solution SHOULD consider the recommendations in the security pillar a Well-Architected Framework such as AWS or Azure (i.e. security pillar[18])	Security Pillar - AWS Well-Architected Framework - Security Pillar[19]	We should conduct a Well architected review on the proposed Alpha solution once fully defined. Now done. Add link here.
	The Infrastructure MUST ensure that each environment can only access its own data and that direct human access to data is not possible	software-engineering-quality-framework/practices/security.md at main · NHSDigital/software-engineering-quality-framework · GitHub[20]	Part of infrastructure requirements and design.
	Automated penetration testing must be supported as a means of providing early sight of potential security vulnerabilities. Test results must be included as part of the environment's reporting such that test failures are apparent and can be investigated	Vulnerability and penetration testing - Service Manual - GOV.UK[21]	Needed as part of Beta build. Need to consult with Engineering community on the best approach to meet this NFR.
	The infrastructure MUST protect cryptographic keys by limiting access to the keys physically, logically, and through user-based and role-based access, and allow administrators to create, delete and control keys that encrypt data stored within the Infrastructure	Provisioning and securing security certificates - NCSC.GOV.UK[22]	Part of infrastructure requirements and design.
	The infrastructure MUST allow certificates to identify and secure communication between resources, and allow administrators to be informed of certificate expiry and to introduce and apply new certificates.	Using Transport Layer Security to protect data - NCSC.GOV.UK[23]	Part of infrastructure requirements and design.

18. https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html
19. https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html
20. https://github.com/NHSDigital/software-engineering-quality-framework/blob/main/practices/security.md#infrastructure-security
21. https://www.gov.uk/service-manual/technology/vulnerability-and-penetration-testing
22. https://www.ncsc.gov.uk/guidance/provisioning-and-securing-security-certificates
23. https://www.ncsc.gov.uk/guidance/using-tls-to-protect-data#section_10

Area	Non-functional requirements	Source	AM Comments:
Patient Identifiable Data	All confidential Patient Identifiable Data (PID) must be securely encrypted whilst in transit. All connections must be assumed to operate on untrusted networks, therefore all external connections must undergo mutual authentication and encryption unless agreed as an exception (e.g. infrastructure services such as NTP and DNS).	• Principles for securing personal data in government services - GOV.UK[24] • TLS Standards[25]	At this stage (Alpha design) we do not anticipate that PID is required to complete a clinical triage. We need to ensure the solution design adheres to this principle and PID does not inadvertently get captured in e.g. via logging.
	External APIs must not expose Patient Identifiable Data in an unencrypted form.		
Observability, Monitoring, Metrics, Dashboards and Alerting (see page 64)	All API access shall be logged with audit trails, including user identity, operation performed and timestamp	• Logging to Splunk - API Platform - CDT Confluence[26] • Principle 13: Audit information and alerting for customers - NCSC.GOV.UK[27]	Logging / observability approach needs defining in its own right to meet these and red lines requirements. Recent developments (TRG August) point towards an in house logging capability (ODIN, Grafana) that we should align to once it completes Beta.
	Logs have clear references indicating their meaning		
	Logs have internal correlation IDs that allow tracing between processes		
	Logs that need to be persisted for less than 3 months will be logged to Splunk only, for operational purposes.		
	Logs that need to be persisted for more than 3 months will be persisted and able to be queried for analytics, reporting and auditing.		

24. https://www.gov.uk/guidance/principles-for-securing-personal-data-in-government-services
25. https://nhsengland.github.io/it-standards/#/security/tls?id=references
26. https://nhsd-confluence.digital.nhs.uk/spaces/APM/pages/119747711/Logging+to+Splunk
27. https://www.ncsc.gov.uk/collection/cloud/the-cloud-security-principles/principle-13-audit-information-and-alerting-for-customers

Area	Non-functional requirements	Source	AM Comments:
Performance (see page 69)	The solution shall meet the following response time requirements: 1. The Triage API **triage** endpoint (POST) shall respond within 500ms at the 95th percentile (i.e. under 0.5 seconds for 95% of the time)	Response times[28]	We understand 500ms to be a 'worst case' SLA. The hypothesis at alpha stage is that the solution should comfortably operate within 100-300ms at scale. Triage operates requiring a 'human in the loop'. Therefore performance of submitting an answer and getting the next question to display on screen should be near enough imperceptible. We recognise that we can only control the API response and not the performance of any system or network that connects to the API.
Availability (see page 54)	The solution shall comply with the requirements outlined by the Platinum API service level[29]	• Platinum API service level[30] • NHS England availability standards[31]	DR/BC approach needs defining separately to meet this. Required as part of Beta including testing. Would feed into clinical safety case. Possibly MDD as well.
	The solution shall achieve a complete service restoration within *[8 supported hours=Sev 1 SLA]* (the RTO) following any unplanned service disruption.	Red Lines Backup Scenario - Overview[32]	

28. https://digital.nhs.uk/developer/guides-and-documentation/reference-guide#response-times
29. https://digital.nhs.uk/developer/guides-and-documentation/reference-guide#service-levels
30. https://digital.nhs.uk/developer/guides-and-documentation/reference-guide#service-levels
31. https://nhsengland.github.io/it-standards/#/infrastructure/availability
32. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-Lines-Backup-Scenario---Overview.aspx

Area	Non-functional requirements	Source	AM Comments:
	The solution shall persist frequent immutable backups, maintaining the information required to enable the functionality of the Triage FHIR API at least once every *[operational day =Review required for limitation of full solution]* (the RPO)	Red Lines Backup Scenario - Overview[33]	
	Data that has failed to ingest due to service disruption will be recovered, re-ingested, and available through the Triage FHIR API within *[8 hours=Sev 1 SLA]*.	Red Lines Backup Scenario - Overview[34]	
Reliability and Resilience (see page 76)	Error rates shall not exceed [0.5%=] for 5xx HTTP server error responses		Would feed into clinical safety case. Possibly MDD as well.
	API request messages exceeding [10MB=default limit imposed by Apigee] shall be rejected	Large payloads - API Platform - CDT Confluence[35]	Don't expect to get anywhere near this limit, not more than a few kb[36]. Alpha poc will give confidence on this.
	API response messages shall not exceed [10MB=default limit imposed by Apigee]	Large payloads - API Platform - CDT Confluence[37]	
	API rate limiting shall be enforced per client with configurable thresholds	• Rate limits[38] • Rate limiting - API Platform - CDT Confluence[39]	This needs carefully defining. We want to protect the service but not throttle in times of high legitimate traffic. Needed for Beta.

33. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-Lines-Backup-Scenario---Overview.aspx
34. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-Lines-Backup-Scenario---Overview.aspx
35. https://nhsd-confluence.digital.nhs.uk/spaces/APM/pages/524891209/Large+payloads
36. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1087792387/NPT-003+Options+Analysis#NPT003OptionsAnalysis-Payload
37. https://nhsd-confluence.digital.nhs.uk/spaces/APM/pages/524891209/Large+payloads
38. https://digital.nhs.uk/developer/guides-and-documentation/reference-guide#rate-limits
39. https://nhsd-confluence.digital.nhs.uk/spaces/APM/pages/123929027/Rate+limiting

Area	Non-functional requirements	Source	AM Comments:
Reproducibility (see page 80)	The API should have reproducible builds, so that every time software is built it produces the exact same result.		IaaC approach. Needed for Beta. Alpha is about testing our risky assumptions.
Scalability (see page 81)	The API infrastructure must support both horizontal scalability (scaling out/in by adding/removing similar components) and vertical scalability (scaling up/down by adding/removing capacity to existing components), meaning it:	• software-engineering-quality-framework/practices/cloud-services.md at main · NHSDigital/software-engineering-quality-framework · GitHub[40] • PERF02-BP05 Scale your compute resources dynamically - Performance Efficiency Pillar[41]	Infrastructure design. Will be tested as part of Alpha POC and load testing.
	The infrastructure is scalable at all layers of the solution to support changes in transaction and data volumes without major upgrades, migrations, or re-engineering		
	Horizontal and vertical scaling is supported in both directions to ensure that increases or decreases in demand and throughput can be catered for		
	The infrastructure should utilise an automated scaling approach		
	When scaling is triggered, either up or down, there must be no degradation of performance experienced by user-initiated or system-initiated requests		
Compatibility and Accessibility (see page 57)	*Any user interface for the Triage API (e.g. for testing) should require strong authentication (MFA); this will be provisioned by CIS2.*		

40. https://github.com/NHSDigital/software-engineering-quality-framework/blob/main/practices/cloud-services.md
41. https://docs.aws.amazon.com/wellarchitected/latest/performance-efficiency-pillar/perf_compute_hardware_scale_compute_resources_dynamically.html

Area	Non-functional requirements	Source	AM Comments:
	Any user interface for the Triage API should comply with the Web Content Accessibility Guidelines WCAG 2.2 (https://www.wcag.com[42])	Catalogue of IT Standards for NHS England[43]	
Compliance and Governance (see page 57)	The solution is in accordance with: • A Well-Architected Framework (AWS or Azure) • The NHS England Solution Architecture Framework assessment • The NHS England Engineering Red-lines	• https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html • Redlines[44]- Engineering Technical Authority Redlines	Reviews to be conducted once alpha design is well defined and repeat reviews periodically or as part of GDS phase change.
	The solution and associated documentation MUST be approved and accepted by the following stakeholders: • Technical Architects responsible for the service (includes analysis, development, functional test and non-functional test) • A certified 'Cloud Expert' • NHS England Solution Assurance • NHS England Clinical Safety Assurance • NHS England Information Governance • NHS England Technical Review and Governance (TRG) • *The NHS England Senior Risk Information Owners (SIRO) for the service* • *The Caldicott Guardian for the service, or a suitable representative from the UK Caldicott Guardian Council* • DUEC Assurance Board • NHS England Live Services Board		

42. https://www.wcag.com/
43. https://nhsengland.github.io/it-standards/#/application-development/common-dev/accessibility
44. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx?csf=1&web=1&e=8VJbnO&CID=dbbda7ae-6ca8-44af-a20c-0326c47991f4

Area	Non-functional requirements	Source	AM Comments:
	Prior to transition to Live Service, the next version of the Triage API MUST be accepted by NHS England Service Management		
	The solution is in accordance with a Data Protection Act 2018 (UK GDPR[45]), and has been reviewed and confirmed as such by NHS England Information Governance	UK GDPR guidance and resources | ICO[46]	
	The solution has been assessed in relation to the Medical Device Directive (MHRA[47]), and if within scope of a Medical Device, compliance has be sought.	Regulating medical devices in the UK - GOV.UK[48]	
Interoperability (see page 62)	The Improving How We Connect Service will include an application programming interfaces (API) that will conform to the NHSE technical standards for API development	API policies and best practice - NHS England Digital[49]	
	The API will be presented through the NHS England API Management platform (Apigee)	• Red Lines[50] • https://digital.nhs.uk/developer/guides-and-documentation/api-policies-and-best-practice#5-api-platform	
	The infrastructure MUST be capable of supporting IPv6-only clients. Internet Protocol version 6 (IPv6) is the latest revision of the Internet Protocol (IP), the communications protocol that provides an identification and location system for computers on networks and routes traffic across the Internet.		

45. https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/
46. https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/
47. https://www.gov.uk/guidance/regulating-medical-devices-in-the-uk
48. https://www.gov.uk/guidance/regulating-medical-devices-in-the-uk
49. https://digital.nhs.uk/developer/guides-and-documentation/api-policies-and-best-practice#4-conform-to-technical-standards
50. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx?csf=1&web=1&e=8VJbnO&CID=dbbda7ae-6ca8-44af-a20c-0326c47991f4

Area	Non-functional requirements	Source	AM Comments:
FinOps (see page 59)	Suitable logging, analytics and dashboards are in place to allow on-going measurement of Infrastructure costings. In this way, the cost optimisation pillar[51] of the AWS Well-Architected Framework can be considered and applied to help drive cost efficiencies in cloud environments in all phases of development: design, delivery, and maintenance.	Cost Optimization Pillar - AWS Well-Architected Framework - Cost Optimization Pillar[52]	To be defined. FinOps measurement could be started as part of Alpha POC testing.
Sustainability (see page 91)	Suitable logging, analytics and dashboards are in place to allow on-going measurement of sustainability targets. In this way, the sustainability pillar[53] of the AWS Well-Architected Framework can be considered and applied to help drive environmental efficiencies in cloud environments in all phases of development: design, delivery, and maintenance.	• Requirements - NHS Architecture manual[54] • Sustainability Pillar - AWS Well-Architected Framework - Sustainability Pillar[55]	
Release Management[56]			We need a clear versioning policy and release management approach but this is more functional requirements.

51. https://docs.aws.amazon.com/wellarchitected/latest/cost-optimization-pillar/welcome.html
52. https://docs.aws.amazon.com/wellarchitected/latest/cost-optimization-pillar/welcome.html
53. https://docs.aws.amazon.com/wellarchitected/latest/sustainability-pillar/sustainability-pillar.html
54. https://architecture.digital.nhs.uk/solution-architecture-framework/requirements#NF
55. https://docs.aws.amazon.com/wellarchitected/latest/sustainability-pillar/sustainability-pillar.html
56. https://nhsd-confluence.digital.nhs.uk/x/kg2RPw

Area	Non-functional requirements	Source	AM Comments:
Production and Path to Live Environments (see page 73)	The solution must support: • a development environment for use by internal NHS England teams • path-to-live environments for use by internal and external parties • a sandbox environment available on the internet for initial engagement and testing • a reference environment available on the internet • a production environment available on the internet that can be used by internal and external parties		

7.1 Actions

- [x] Conduct engineering red line assessment on the proposed Alpha solution once fully defined - Now done - Red Lines Assessment[57]
- [x] Conduct SA Framework assessment on the proposed Alpha solution once fully defined. Completed by Tharack. Afzal Mufti to add link here.
- [x] Conduct Well Architected review on the proposed Alpha solution once fully defined. Prioritise pillars e.g. Security first. Afzal Mufti completed, add link to summary report and tracker.
- [ ] Conduct SEQF review on the proposed Alpha solution once fully defined. Not yet done.
- [ ] Engage with engineering and cyber teams on how to meet automated pen test NFR.
- [ ] Conduct NFR review (this page) on the proposed Alpha solution once fully defined. Now in beta. Needs scoring.
- [ ] Logging / observability approach needs defining
- [ ] Disaster recovery / Business continuity approach needs defining to meet Platinum SLA
- [ ] Approach to API Rate limits needs defining
- [ ] Alpha POC scalability
- [ ] FinOps approach needed (dashboards, KPIs, correct tagging etc)
- [ ] Consider adding additional NFRs from the Sample Generic NFRs v1.0 - RO.dotx[58]

57. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1320957881/Red+Lines+Assessment
58. https://nhsd-confluence.digital.nhs.uk/download/attachments/917175969/Sample%20Generic%20NFRs%20%20v1.0%20-%20RO.dotx?api=v2&modificationDate=1754930600786&version=1

7.2 NFR: Availability

7.2.1 Terminology

- Recovery Time Objective (RTO) is the targeted duration of time within which a service must be restored after a disaster (or disruption) in order to avoid unacceptable consequences associated with a break in business continuity. It is therefore considered the period of time the business can be without the service, without incurring significant risks or significant losses. The events that mark the start and end of the RTO duration are typically agreed between BC and ITSC teams, and is usually defined as the interval from the cessation of the service to its full restoration to the end users.
- Recovery Point Objective (RPO) represents the maximum period of time during which recent data is considered as permanently lost in the event of a major incident, and is not a direct measure of the quantity of such loss. For example, if a Business Continuity plan is to 'restore the data up to the last available backup', then the RPO is the maximum interval between the time of the most recent data that can be restored and the time of the disaster event. RPO is expressed backward in time (that is, into the past) from the instant at which the failure occurs, and can be specified in seconds, minutes, hours, or days.
- A Maintenance Window is a period of time designated in advance by the technical staff, during which preventive maintenance that could cause disruption of service may be performed.

7.2.2 Background

- Availability... is... *"the degree to which a system, subsystem or equipment is in a specified operable and committable state at the start of a mission, when the mission is called for at an unknown, i.e. a random, time."* (Source: https://en.wikipedia.org/wiki/Availability)
- Cloud Hosting providers offer hosting services in Regions throughout the world. Each Region is a separate geographic area and each Region has multiple, isolated locations known as Availability Zones (AZs). An Availability Zone comprises one or more distinct datacentres.

7.2.3 Assumptions

- All requirements relate:
  - only to the *Production* environment as this is the environment in which t (see page 81)he patient triage api users directly interact.

7.2.4 Acceptance Criteria

7.2.4.1 *1. Availability Target*

This requirement seeks to highlight the contribution of the patient triage api Infrastructure to the overall availability target of the patient triage api applications. The patient triage api Infrastructure is resilient to AZ-level failures within a single region, with regional incidents handled via disaster recovery processes.

Requirement:
The patient triage api Infrastructure must take advantage of multiple Public Cloud Availability Zones offered by the cloud hosting provider within a single region to ensure that the underlying availability target for the Patient Triage Api of 99.90% is preserved.

Disaster recovery scenarios must be scoped to a Region.

- Each datacentre in a Region is considered 'highly available' by default, however, although very rare, failures can occur that affect the availability of instances that are in the same location.

Business Benefit
The availability of patient triage api services matches the demands of their target demographic.

7.2.4.2 *2. Availability Periods*

This requirement seeks to define the expected operational periods of use to help ensure that the availability of patient triage api services match the demands of the target demographic.

The availability periods for patient triage api must be: 24 hours a day, 7 days a week (24*7), There is an expectation that the service will always be available event during periods of maintenance. In these period some functionality maybe impaired, or the resilience of then service in this period may be impacted. This may be inherited from the cloud hosting provider, all steps should be taken to limit the impact to end users particularly search queries that may directly impact patient health. Maintenance windows of planned change activity should not exceed 150 mins per month with a maximum of 60 mins for any single maintenance activity.

TODO: Confirm maintenance window patient triage api has a scheduled maintenance window of 09:00 - 10:00 every Tuesday Morning.

Business Benefit:
Balancing the availability of the patient triage api Service with the need to perform maintenance and upgrades.

7.2.4.3 *3. Disaster Recovery and Business Continuity*

Patient triage api Services and Infrastructure must be capable of supporting the necessary disaster recovery and business continuity options in order to achieve a Recovery Time Objective (RTO) of 2 hours, aligning with a Platinum Service as defined by NHS England Service Management PGSB classification..

Patient triage api Infrastructure must be capable of supporting the necessary disaster recovery and business continuity options in order to achieve a Recovery Point Objective (RPO) of close to zero seconds.

Business Benefit:
Keeping the service available when it would have otherwise have probably failed due to an incident.

7.2.4.4 4. API availability

- API services should be available in line with the core patient triage api application availability periods.
- The core availability periods are: 24 hours a day, 7 days a week (24*7), excluding any scheduled maintenance windows.

Business Benefit
External API service availability will match core patient triage api availability meaning no variation in service to the end user

7. Global Access

The patient triage api Infrastructure must limit the location from which the patient triage api services can be accessed i.e. patient triage api and services are only available from UK registered IP, subject to authentication and authorisation.

Business Benefit:
Professional and Authority Users are only expected to access the patient triage api services within the context of direct healthcare to UK based patients. This restriction is to act as a first line of defence against bad actors across the globe.

7.2.4.5 *6. Release downtime*

The Patient triage api **MUST** use zero-downtime blue/green deployments[59] for all planned deployments to the production environment.

-

59. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx#cloud-4

7.3 NFR: Compatibility and Accessibility

7.3.1 Background

- Compatibility assess how well the system interacts with other applications, processes, and hardware. They ensure that the software can coexist with existing systems and does not introduce conflicts that could hinder functionality or user experience

---

7.3.2 Assumptions

- All requirements relate:
  - only to the *Production* environment as this is the environment in which Patient Triage Api users directly interact; and,
  - to the *on-going operation* of Patient Triage Api .

7.3.3 Acceptance Criteria

7.3.3.1 *1. User Interface Compatibility*

Any User Interface created by Patient Triage Api MUST require strong authentication (MFA) this will be provisioned by CIS2. As such the system compatibility with CIS2 is documented in the NHS Spine Warrantied Environment Specification (wes)[60] providing a clear guide to supported OS and browsers. Patient Triage Api MUST match these compatibility needs.

Business Benefit:

Ensures that users if the Service have a clear expectation of the OS's and Browsers that the system works with and has been tested against.

7.4 NFR: Compliance and Governance

7.4.1 Background

- Compliance refers to adhering to laws, regulations, standards, and policies relevant to an organization's operations.
- Governance involves establishing a framework of policies, roles, responsibilities, and processes that dictate how an organization's resources are managed and used.
- Service Acceptance Criteria (SAC) is *"...a set of criteria used for service acceptance testing to ensure that an IT service meets its functionality and quality requirements and that the service*

60. https://digital.nhs.uk/services/spine/spine-technical-information-warrantied-environment-specification-wes

provider is ready to operate the new service when it has been deployed." (Source:_ https://wiki.en.it-processmaps.com/index.php/ITIL_Glossary/_ITIL_Terms_S#Service_Acceptance_Criteria_.28SAC.29).

7.4.2 Assumptions

- All requirements relate to *all* environments:
  - Pre-Production environments as these are used during the software development process
  - Production environment as this is the environment in which the Patient Patient Triage Api users directly interact.
- It is assumed that the NHS England Technical Reference Group (TRG) encompasses NHS England Cyber Security.

7.4.3 Acceptance Criteria

7.4.3.1 *1. Governance - Acceptance*

Prior to transition to Live Service, the next version of Find the Right Sevice MUST be accepted by:

- NHS England Service Management

Business Benefit:

7.4.3.2 *2. Governance - Accordance*

The Patient Triage Api solution is in accordance with the NHS England Solution Architecture Framework assessment and has been reviewed and confirmed as such by an NHS England Solution Architect.

The Patient Triage Api solution is in accordance with The NHS England Engineering Red-lines, and has been reviewed and confirmed as such by an NHS England Principle System Engineer.

Business Benefit:
A Well-Architected framework provides a consistent approach to evaluating architectures, by providing guidance to help implement designs that will scale with application needs over time. The Solution Architecture Framework allows assessment of the maturity of the service against NHS England agreed criteria. Engineering Red-lines look to ensure consistency of approach of engineering and to establish best practice across NHS England.

7.4.3.3 *3. Compliance - Accordance*

The Patient Triage Api solution is in accordance with a Data Protection Act 2018 (UK GDPR[61]), and has been reviewed and confirmed as such by NHS England Information Governance

The Patient Triage Api solution is assessed and deemed out of scope of the Medical Device Directive (MHRA[62]), if at any point Patient Triage Api starts to adopt features that may bring it within scope of a Medical Device, Compliance should be sought.

Business Benefit:
Ensuring Compliance with any legal obligations Patient Triage Api may be subject to.

7.4.3.4 *4. Assurance and Approval*

The Patient Triage Api solution and associated documentation MUST be approved and accepted by the following stakeholders:

- Patient Triage Api Architects (includes analysis, development, functional test and non-functional test)
- A certified 'Cloud Expert'
- NHS England Solution Assurance
- NHS England Clinical Safety Assurance
- NHS England Information Governance
- NHS England Technical Review and Governance (TRG)
- The NHS England Senior Risk Information Owners (SIRO) for Patient Triage Api
- DUEC Assurance Board
- NHS England Live Services Board

7.5 NFR: FinOps

Suitable logging, analytics and dashboards are in place to allow on-going measurement of Infrastructure costings.

In this way, the cost optimisation pillar[63] of the AWS Well-Architected Framework can be considered and applied to help drive cost efficiencies in cloud environments in all phases of development: design, delivery, and maintenance.

Business Benefit:
NHS England can monitor costs associated with managing the entire Patient Triage Api, allowing on-going refinements to usage and infrastructure to be made.

61. https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/
62. https://www.gov.uk/guidance/regulating-medical-devices-in-the-uk
63. https://docs.aws.amazon.com/wellarchitected/latest/cost-optimization-pillar/welcome.html

7.5.1 Provisional content

7.5.2 Assumptions

All requirements apply to all environments:

- Pre-Production environments, as these are used during the software development process.
- Production environment, as this is the environment in which the Patient Triage Api users directly interact.

7.5.3 Acceptance Criteria

7.5.3.1 1. Tagging of AWS Resources

Tagging enables filters to be set in AWS Cost Explorer for cost attribution, governance, and reporting.

Example tags:

- Environment (e.g. dev, test, prod)
- Team
- Application
- CostCentre
- Owner
- Service

7.5.3.2 2. Cost Analysis Tools

AWS Cost Explorer is the primary tool for analysing AWS resource costs.

- It MUST be used to monitor usage trends, forecast spend, and identify anomalies.
- Reports generated from Cost Explorer SHOULD be reviewed monthly by the relevant teams.

7.5.3.3 3. CloudHealth Access

Each team MUST ensure that at least one Infrastructure Engineer has access to CloudHealth by **end of November 2025.**

- https://apps.cloudhealthtech.com/login

- To request access, contact: c.squibb@nhs.net[64]

7.5.3.4 4. CloudHealth Usage

- CloudHealth SHOULD be used as an alternative tool for cost analysis and optimisation.
- Teams SHOULD use CloudHealth to validate tagging compliance and identify underutilised resources.

7.5.3.5 5. AWS Budgets and Notifications

AWS Budgets MUST be configured in all environments by **end of December 2025**, unless restricted by Terraform version (i.e. using version not above 5.84).

- Budgets MUST be set at the environment, team, or application level.
- SNS notifications MUST be configured to alert stakeholders when thresholds are exceeded.

Alerts MUST be sent to:

- The team's designated email distribution list
- The team's Slack channel
- A dedicated Slack channel for cost alerts (see below)

7.5.3.6 6. New Teams Channel for Billing Alerts

A new Teams channel named [TBC] will be created to centralise billing notifications and cost alerts.

- Purpose: To receive automated alerts from AWS Budgets and facilitate quick response to cost anomalies.
- Owner: Has to set up and manage the channel by **end of Oct**.

7.5.3.7 7. Quarterly Cost Review

Formal cost reviews will be conducted every three months, starting early January 2026.

- These reviews SHOULD take place during the Infrastructure Community Meeting.
- Reports from AWS Cost Explorer and CloudHealth will be discussed.
- Action items SHOULD be documented and tracked for follow-up.

---

64. mailto:c.squibb@nhs.net

7.5.4 Task Priority Breakdown

Priority	Task
High	CloudHealth Access New Slack Channel Setup
Medium	AWS Budgets and Notifications Quarterly Cost Review follow-up

7.6 NFR: Interoperability

7.6.1 Background

- "Interoperability is a characteristic of a product or system, whose interfaces are completely understood, to work with other products or systems, present or future, in either implementation or access, without any restrictions." (Source: http://interoperability-definition.info/en/)
- The intention of this requirement is to ensure that all points of integration with The Patient Triage Api Service are identified and tested.

7.6.2 Assumptions

- All requirements relate to *all* environments:
  - Pre-Production environments as these are used during the software development process
  - Production environment as this is the environment in which Patient Triage Api users directly interact.

7.6.3 Acceptance Criteria

7.6.3.1 ***1. External API***

Patient Triage Api will include an application programming interfaces (API) to enable all functions to be undertaken using third party developed user interfaces.

- The API will not maintain state. 'Stateless' means there is no record of previous interactions and each interaction request must be handled based entirely on information that comes with it. Enterprise services are typically high volume and mixed usage from the consuming applications' perspective and stateless applications scale more effectively and offer easier management and recovery after failure conditions.

- The API will not enforce message sequence dependency. It follows that:
  - Each API request will be validated and actioned entirely on its own merits.
  - The API cannot and *must not* hold any locks on any Patient Triage Api resources between API calls because there is no guarantee that a particular call will be made within any expected timeframe. Therefore, any locks on Patient Triage Api resources should only be held for the duration of a single API call.
  - Each API call either ends completely and correctly or the whole call fails leaving no changes to core Patient Triage Api state. i.e. The Patient Triage Api core state must remain valid regardless of how an API call ends.
  - No API call processing should assume that incoming field values are valid. All field values must be validated on every call.

Business Benefit:
The patient Triage API will be able to provide the most up to date data allowing host systems to upgrade by simply changing their clinical data version. Updates can be rolled out more quickly and clients can upgrade when they are ready to.

7.6.3.2 **2. API Management**

All APIs will present APIs through the NHS England API Management platform (Apigee)

Business Benefit:
The Patient Triage Api will present a common consistent approach to specification of APIs

7.6.3.3 **3. Snomed CT**

The Patient Triage Api will implement the triage outcome model (TOM) when it goes live. This is likely going to be after the Patient Triage Api has begun its initial rollout.

Business Benefit:
Adoption of Snomed CT by The Patient Triage Api allows for down stream providers to understand the internationally agreed coding. Enabling transparency of service capability and future opportunities by other 3rd party clinical diagnostic systems.

7.6.3.4 ***6. IP Support***

The Patient Triage Api Infrastructure MUST be capable of supporting IPv6-only clients. Internet Protocol version 6 (IPv6) is the latest revision of the Internet Protocol (IP), the communications protocol that provides an identification and location system for computers on networks and routes traffic across the Internet.

Business Benefit:
Conformance requested by NHS England.

7.7 NFR: Observability, Monitoring, Metrics, Dashboards and Alerting

7.7.1 Background

- *"Service Monitoring and Control (SMC) is the real-time observation of and alerting about health conditions (characteristics that indicate success or failure) in an IT environment. It helps to ensure that deployed services are operated, maintained, and supported in line with the service level agreement (SLA) targets agreed to between the business and IT."*
(Source: https://technet.microsoft.com/en-us/library/cc543299.aspx)
- Currently, the Patient triage Api Infrastructure is planning on utilising ODIN and Cloudwatch these both need to be completed.
    - ODIN is used for Logging alerting and dashboards
    - Cloudwatch is used for Logging, Metrics and Events.

7.7.2 Assumptions

- All requirements relate to *all* environments:
    - Pre-Production environments as these are used during the software development process.
    - Production environment as this is the environment in which Patient Triage Api users directly interact.

7.7.3 Acceptance Criteria

7.7.3.1 ***1. Health Monitoring***
This requirement seeks to ensure that the Patient Triage Api Infrastructure is able to be monitored for operational health.

The solution must support health monitoring.

- This MUST be available remotely to the environment being monitored.
- This MUST support a real-time or near-real-time operations management capability by exposing an interface to allow distribution of the instrumented information.
- The maintenance and support effort SHOULD be proactive, minimised and where possible, automated.

Specifically, the health monitoring must include:

- Patient Triage Api application health monitoring. This allows questions such as *"is the ers-pds-gateway Java service currently working?* to be answered.
- Patient Triage Api Infrastructure health monitoring. This allows questions such as *"are the CPU, memory, IO and internal/external network connections currently working?"* to be answered.
- system-wide health monitoring. This allows questions such as *"are the perimeter defence (IPS/IDS), N3/HSCN connectivity, firewalls, and load balancers currently working"* to be answered.

Business Benefit:
Monitoring information will facilitate the identification of developing faults, traffic prioritisation, and capacity management. The system will avoid known bad service nodes and instead route requests to known good nodes therefore improving the availability of the system.

7.7.3.2 *2. Performance Monitoring*

This requirement seeks to ensure that the Patient Triage Api is able to be monitored for performance.

Requirement:
The solution must support performance monitoring.

- This must be available remotely to the environment being monitored.
- This must support a real-time or near-real-time operations management capability by exposing an interface to allow distribution of the instrumented information.
- The maintenance and support effort should be proactive, minimised and where possible, automated.

Specifically, the performance monitoring must include:

- Patient Triage Api application performance monitoring. This allows questions such as *"how is the ers-pds-gateway Java service currently performing?* to be answered.
- Patient Triage Api Infrastructure performance monitoring. This allows questions such as *"how is the CPU, memory, IO and internal/external network connections currently performing?"* to be answered.
- OS level performance monitoring. This allows questions such as *"can we check the performance and usage of the file system?"* to be answered.
- system-wide performance monitoring. This allows questions such as *"how is the perimeter defence (IPS/IDS), N3/HSCN connectivity, firewalls, and load balancers currently performing"* to be answered.

Specifically, for the each API type, performance monitoring must include:

- Transactions (API requests) per second per API endpoint.
- Response time for each endpoint.
- Combined response time for all API endpoints.
- Failures (by type).
    - Code and detail of the failure.
    - % of errors against overall responses.

Business Benefit:
The performance of the Patient Triage Api application services and the Patient Triage Api Infrastructure can be measured and monitored to ensure they match the demands of their target demographic.

7.7.3.3 *3. Infrastructure Audit Logging*

This requirement attempts to ensure that infrastructure level logs are captured to describe the operations performed on the infrastructure resources (components) by both human and system users.

Each infrastructure component within the Patient Triage Api architecture must be capable of recording infrastructure events.

An 'infrastructure event' is a operational-level transaction performed on any component or service within the Patient Triage Api Infrastructure.

The repository of infrastructure events is known as the 'Infrastructure Log'.

The Infrastructure Log itself must be secure, purgeable, transportable, exportable, queryable and human readable.

Logs should be persisted in line with NHS Records Management Code of Practice[65]

The Infrastructure Log MUST support:

- Triage - the ability to mine the Infrastructure Log data either close to the event or in a historical manner
- Reporting - allow the Infrastructure Log data to participate in reporting to cater for Management Information needs

For each infrastructure event, the following must be persisted:

- parameters received;
- response given;
- details of the nature of the log event and the identity of the associated data, the changes to the data including type of change;
- the date and time on which the log event occurred;
- a sequence number to protect against malicious attempts to subvert the logs by, for example, altering the system date.

Each Patient Triage Api Infrastructure component must output its infrastructure logs will be stored in a local repository (e.g. ODIN indexes) as well as being capable of being forwarded to another instance (e.g. NHS England's SIEM).

Infrastructure events recorded by the Patient Triage Api Infrastructure should be categorised according to the 'Log Levels', below:

---

65. https://transform.england.nhs.uk/information-governance/guidance/records-management-code/

ERROR	Operations and Support	Unexpected harmful events - major technical and functional breakdowns directly impacting system availability.
WARN	Operations and Support	Unexpected events which should not be harmful - minor technical and functional breakdowns not directly impacting system availability
INFO	Operations and Support	Handover between layers in the component architecture (verbose, includes transfer within same layer)
DEBUG	Developers	Diagnostic output, should only be turned on in production upon request - technical messages embedded in programme code.
TRACE	Developers	Low level or high volume diagnostic output, should only be enabled on request logs - technical messages embedded in programme code.

The outputs of Infrastructure Log data must be controlled by settings per Patient Triage Api Infrastructure component. When set, output must commence with immediate effect (subject to any short cache delays).

Business Benefit:
Provides infrastructure level logs describing the operations performed on the infrastructure resources (components) by both human and system users.

The Patient Triage Api Infrastructure and Patient Triage Api applications will prepare and store all Activity Log, Audit Log, Operations Log, and Infrastructure Log data in the English language.

Business Benefit:
Readability and quicker resolution of technical/support issues.

7.7.3.4 4. Operational Audit Logs

Each Patient Triage Api application component within the Patient Triage Api architecture must be capable of recording operational events.

An operational event is a system-level transaction.

The repository of operational events is known as the "Operations Log".

The Operations Log itself must be secure, purgeable, transportable, exportable, queryable and human readable. It must be possible to correlate operations log data to provide an end-to-end view of a user's interaction with Patient Triage Api. All interactions with an external API will be subject to operations logging

Logs should be persisted in line with NHS Records Management Code of Practice[66]

For each operational event, the following must be persisted:

- parameters received;

66. https://transform.england.nhs.uk/information-governance/guidance/records-management-code/

- response given;
- details of the nature of the operational event and the identity of the associated data, such as Patient Id, Message Id, the changes to the data including type of change;
- the date and time on which the operational event occurred;
- a sequence number to protect against malicious attempts to subvert the operations log by, for example, altering the system date;
- transaction identifier, to support end-to-end transaction analysis (this will match the Transaction Id recorded in the Audit Log)

Business Benefit:
Provides system level logs describing each request's and other external interactions' processing within and by the system.

7.7.3.5 5. Audit Logs

Background:
Under the Data Protection Act 1998, the NHS participates in whole of government process process known as a 'Subject Access Request'. NHS England responds to such requests on behalf of NHS by supplying the personal information held about the requester. The patient triage api auditing facility broadly captures system information to understand "who saw or did what to who".

Requirement:
An auditable event is a specific user-centric transaction of interest to the NHS. Each component within the Patient Triage Api architecture must be capable of recording auditable events.

The repository of auditable events is known as the "Audit Log". The Audit Log itself must be secure, purgeable, transportable, exportable, queryable and human readable. It must be possible to correlate audit log data to provide an end-to-end view of a user interaction.

This NFR is the 'top-level' requirement for auditing.

All auditable events logged as a result of a single transaction are to be logged with the same the date and time on which all auditable events occurred *and/or* with the same Transaction Id. This will allow them to be 'traceable' to a single user or system action.

Logs should be persisted in line with NHS Records Management Code of Practice[67]

All interactions with Patient Triage Api via the External API will be subject to audit logging to the same level as implemented by with any User Interface.

Business Benefit:
Supports auditing by Caldicott Guardians; and processing Subject Access Requests submitted via Freedom of Information.

67. https://transform.england.nhs.uk/information-governance/guidance/records-management-code/

7.7.3.6 *6. Alerting*

This requirement seeks to ensure that NHS England service management systems or colleagues can be notified when an operational event of interest occurs as a result of interactions with the Patient Triage Api applications and the supporting cloud-based infrastructure.

The solution allows alert conditions to be configured.

Should an alert condition be triggered, the solution will support an alert containing relevant information about the event to be sent to a configurable channel such as email, instant messenger, a specific endpoint or a subscribed service.

Business Benefit:
NHS England service management systems or colleagues can be notified when an operational event of interest occurs as a result of interactions with the Patient Triage Api applications and the supporting infrastructure.

7.7.3.7 *7. Analytics*

The solution must support the discovery, interpretation, and communication of meaningful patterns in data related to the interactions with Patient Triage Api applications and the supporting Patient Triage Api cloud-based infrastructure.

Any failure to record Analytics for an interaction must **not** affect the success or failure of the interaction itself.

Business Benefit:
The Patient Triage Api Infrastructure is ready to participate in analytics processes.

7.8 NFR: Performance

7.8.1 2. Scope

These requirements apply to:

- All endpoints of the **Patient Triage API**
- Consumers accessing the API through the NHS England API Management platform
- Normal, peak, and degraded scenarios
- All AWS-managed components involved in processing the Triage request

https://digital.nhs.uk/developer/guides-and-documentation/reference-guide#response-times

---

7.8.2 3. Performance Objectives Summary

Category	AWS-Specific Requirement
Response Time	The **Triage API triage endpoint (POST)** must respond within **300 ms at P95**. Measured at the API Gateway boundary within the NHS England AWS account.
Throughput	Must support expected and forecast RPS with AWS autoscaling.
Scalability	Must autoscale using AWS Lambda concurrency.
Resilience	Error rate must remain < 0.1% during expected and peak load.
Load	Load must be at least 2,147 journeys

7.8.3 4. Response Time Requirements

7.8.3.1 4.1 Defined Response Time SLA

The solution shall meet the following response time requirement:

> ***The Triage API triage endpoint shall respond within 300 ms at the 95th percentile (i.e., under 0.3 seconds for 95% of requests).***

7.8.3.2 4.2 AWS Considerations

This SLA must hold accounting for:

- API Gateway or Application Load Balancing latency
- Lambda execution time or container task processing
- VPC cold start behaviour (if Lambda is VPC-attached)
- DynamoDB/RDS read/write latency
- Cross-AZ traffic

7.8.4 5. Throughput & Load Requirements

The Triage API must:

- Sustain projected normal load with < P95 latency threshold **Load TBC**
- Handle peak load via:
  - API Gateway burst capacity
  - Lambda concurrency scaling
- Maintain performance during scale-out events

7.8.5 6. Scalability Requirements

Area	Requirement
Compute Scaling	Must automatically scale via AWS Lambda concurrency
Stateless Design	API functions or services must be stateless
Database Scaling	DynamoDB auto-scaling must support peak throughput.
Caching	Responses or lookups cached using caching where appropriate.

7.8.6 7. Reliability Under Load

7.8.6.1 **Error Rate**

- Overall error rate must remain **< 0.1%** during peak loads.
- No more than **0.01%** 5xx errors under normal load.

7.8.6.2 **AWS-Specific Resilience Expectations**

- Multi-AZ operation for compute and database layers
- Throttling protection via API Gateway/WAF

7.8.7 8. Performance Testing Requirements

7.8.7.1 **Required Test Types**

- Load testing around P95 response time threshold (300 ms)
- Spike testing to validate autoscaling responsiveness

- Soak testing to confirm sustained latency compliance

7.8.7.2 AWS Testing Considerations

- Validate Lambda concurrency scaling and provisioned concurrency if enabled
- Measure API Gateway integration latency
- Verify database performance under load (DynamoDB RCUs/ WCUs)

7.8.8 9. Monitoring & Observability Requirements

Area	AWS Requirement
Dashboards	Odin dashboards tracking P50, P95, P99 latency specifically for Triage POST endpoint.
Alerts	Alerts for P95 latency > 300 ms, error rates, and saturation signals.
Tracing	AWS X-Ray required for end-to-end latency analysis.
Logging	Centralized logs in available in CloudWatch and exportable to NHS England observability platforms. These include ODIN and ITOC

7.8.9 10. SLAs, SLOs & SLIs

Metric	Target
P95 Response Time (Triage POST)	**< 300 ms**
Availability	99.9%
SLIs Monitored	Latency, throughput, error rate, autoscaling response time

SLA will align with the agreed upon NHS England service level classification. We are currently targeting Bronze and will ramp up to a Platinum level service.

7.8.10 11. Risks & Assumptions

7.8.10.1 Risks

- Database or downstream services exceeding latency budgets
- AWS regional service throttling
- Cold starts impacting P95 if Lambda concurrency isn't pre-provisioned

7.8.10.2 Assumptions

- Architecture supports horizontal scaling
- API remains stateless
- Network design complies with AWS best practices

7.9 NFR: Production and Path To Live environments

7.9.1 Assumptions

1. These criteria define the core environments. Additional environments may be required by the individual service teams to satisfy their individual needs.

7.9.2 Acceptance Criteria

7.9.2.1 Root Domain Name

1. The solution will host one or more externally available services as APIs. These external services MUST be routed via API Management, and therefore MUST be a path of the "api.service.nhs.uk[68]" domain.
2. The API Management solution requires an endpoint that can be reached by the host suppliers at a fixed domain name. These internal endpoints MUST have a top-level domain of "patient-triage.service.nhs.uk[69]".

7.9.2.2 Development Environments

This requirement seeks to ensure that the patient triage api infrastructure is able to be adapted, fixed and improved by development teams.

Development Environment (dev)

1. The solution must support a development environment.

68. http://api.service.nhs.uk
69. http://patient-triage.service.nhs.uk

2. The dev environment must be kept up to date with the latest changes in the main development branch of the project.
3. The solution must support development environments for use by internal NHS England teams. These should be suited to the needs of each individual item of infrastructure.
4. The following requirements apply to all patient triage api infrastructure that will have a corresponding set of Path-to-Live and Production environments.
    a. Development environments for APIs SHOULD be accessible via the non-production API Management platform.

Business Benefit
The patient triage api solution is able to be actively developed and tested by the teams delivering the solution, enabling efficient delivery of products and services that satisfy our user needs.

7.9.2.3 Path-to-Live API Environments

This requirement seeks to ensure that the Patient Triage Api infrastructure can be tested and integrated with by internal and external parties, and to ensure changes to Patient Triage Api infrastructure do not impact connected downstream systems.

The solution must support path-to-live environments for use by internal and external parties for testing their implementation of their integrations with our services.

The following requirements apply to all Patient Triage Api infrastructure that will have a corresponding set of development and production environments.

The solution SHOULD support a sandbox environment available for initial engagement and testing. The requirements for this environment are:

- The sandbox environment MUST contain a small set of data for demonstration purposes only.
- The sandbox environment MUST be available on the internet.
- The sandbox environment MUST be accessible without any authentication and authorisation.
- The data within the sandbox environment SHOULD be periodically reset back to an basic initial state.
- Any sandbox environment APIs MUST be available as a path of the sandbox.api.service.nhs.uk/patient-triage[70] host.

The solution MUST support an integration environment. The requirements for this environment are:

- The integration environment MUST be available on the internet.
- The integration environment MUST implement the same authentication and authorisation patterns used by the production environment.
- The data held within the integration environment MUST be treated as sensitive information due to the active engagement by external parties.
- The data held within the integration environment SHOULD be persistent and treated in the same regard as the production environment.

70. https://sandbox.api.service.nhs.uk/patient-triage

- The integration environment SHOULD be a managed environment with a regular release cadence and schedule.
- Releases to the integration environment MUST be clearly communicated to all integrated parties ahead of each release to enable early engagement and testing.
- Any integration environment APIs MUST be available as a path of the int.api.service.nhs.uk[71] host.

The solution MUST support a reference environment. The requirements for this environment are:

- The reference environment MUST be available on the internet.
- The reference environment MUST implement the same authentication and authorisation patterns used by the production environment.
- The reference environment SHOULD mirror the infrastructure of the live environment.
- The reference environment MUST contain a similar volume of data as the production environment.
- Any reference environment APIs MUST be available as a path of the ref.api.service.nhs.uk[72] host.

Business Benefit:
A clear environment strategy provides a path to onboarding and using the services provided by the Patient Triage Api solution.

The sandbox environment allows early exploration of the capabilities of the service, and helps to aid in discovery of the service and answer initial questions about the use of the service and whether there is a need for integration by another party.

The integration environment allows for integration testing by parties internal and external to the Patient Triage Api programme to aid in onboarding and conformance.

The reference environment allows for reliable testing of the service to ensure continuity of service in a live environment. This de-risks large changes to the production environment, as equivalent changes can be fully tested in an isolated environment that mirrors the production service.

7.9.2.4 Production Environment

This requirement seeks to ensure that the Patient Triage Api infrastructure can be operated in a secure and protected environment for direct clinical and non-clinical use cases.

The solution must support a production environment that can be used by internal and external parties to support direct and indirect clinical use cases.

The environment MUST only be accessible once the integrating party* has completed a formal engagement and onboarding process. Requirements for the onboarding of the service can be found in section TODO.

All other non-functional requirements also apply to the production environment of the Patient Triage Api solution. These requirements are supplemental and only apply to the production environment.

71. http://int.api.service.nhs.uk/
72. http://ref.api.service.nhs.uk/

- The production environment MUST be available on the internet.
- The production environment MUST implement appropriate authentication and authorisation patterns to protect the service.
- The data within the production environment MUST be treated as sensitive and persistent.
- Access to the production environment or infrastructure MUST follow the principle of least privilege. This applies for both internal parties operating the service and external parties accessing the service.
- Access and changes to the production infrastructure MUST be clearly tracked and recorded. This access and change log MUST be audited at least once per calendar month.
- The production environment MUST follow a release cadence and schedule for regular releases.
- All changes to the production environment MUST be discussed and approved by service management.
- All changes to the production environment MUST be tested in the reference environment before being released.
- All changes to the production environment SHOULD be promoted through each of the path-to-live environments following the wider release strategy.
- Breaking changes to the production environment MUST be clearly communicated to all internal and external stakeholders within a relevant time schedule.
- Breaking changes to the production environment MUST be available in the integration environment at least 5 business days before the scheduled release to production to enable supplier testing.
- New features and breaking changes to the production environment SHOULD be making use of feature flags to enable easier toggling and roll-back of functionality.

*check API-M terminology for clarity

Business Benefit

The Patient Triage Api solution is able to be accessed by internal and external parties providing products that satisfy their user needs. The solution is viewed as reliable and trusted, and operated in a safe manner.

7.10 NFR: Reliability and Resilience

7.10.1 Background

- Reliability is the outcome and resilience is the way you achieve the outcome
- Resilience is the ability to provide and maintain an acceptable level of service in the face of faults and challenges to normal operation.

7.10.2 Assumptions

- All requirements relate:
  - only to the *Production* environment as this is the environment in which patient triage api users directly interact; and,
  - to the *on-going operation* of the patient triage api.

7.10.3 Acceptance Criteria

1. Overall Resilience

The patient triage api Infrastructure MUST take advantage of multiple Availability Zones offered by a cloud hosting provider within a single region to support the underlying patient triage api resilience objective.

Each Availability Zone is power independent and network independent (and therefore also allows for security independence).

There is typically very little spatial isolation - Availability Zones need to be very close to each other, usually within miles, to allow very low network latency between each other over private links.

In addition, the patient triage api Infrastructure should have no single points of failure.

The solution SHOULD consider the recommendations in the reliability pillar a Well-Architected Framework such as AWS or Azure (i.e. reliability pillar[73])which provides guidance to help apply best practices to ensure reliability in all phases of development: design, delivery, and maintenance.

Business Benefit:
The patient triage api Infrastructure and patient triage api maintain an acceptable level of service in the face of faults and challenges to normal operation.

7.10.3.1 *2. Resilience and Security*

The patient triage api Infrastructure MUST be resilient to security attacks typically associated with cloud computing, including:

- Denial of Service (DoS) attacks - where an attacker overloads the target cloud system with service requests so that it stops responding to any new requests and hence makes resources unavailable to its users.
- Code Injection attacks - where an attacker tries to inject malicious code (a.k.a. malware) into a vulnerable component of the service.
- Side Channel attacks - where an attacker attempts to compromise the cloud system by placing a malicious virtual machine in close proximity to a target cloud server system and then launching a side channel attack.

---

73. https://docs.aws.amazon.com/wellarchitected/latest/reliability-pillar/welcome.html

- Authentication attacks - authentication is a weak point in cloud computing services which is frequently targeted by an attacker by such means as Brute Force; Dictionary; 'Shoulder Surfing'; Replay; Phishing and Key Logging.
- Man-In-The-Middle (MIM) attacks - where the attacker intercepts messages in a public key exchange and then re-transmits them, substituting their own public key for the requested one, so that the two original parties still appear to be communicating with each other.
- The patient triage api application must be resilient to security attacks, including

  Click-jacking- patient triage api or parts of the patient triage api application, cannot be embedded within another webpage that doesn't belong to patient triage api , so that third parties cannot embed patient triage api in another webpage, to trick users into selecting a webpage element which is invisible or disguised as another element.

Business Benefit:
Reduces the chance of an attacker reducing information assurance.

7.10.3.2 *3. Process Resilience*

The patient triage api Infrastructure must support suspension and resumption of patient triage api application processes without corruption or loss of data, including:

- The data ingestion process

Business Benefit:
Ensures there is no loss or corruption of data during batch operations.

7.10.3.3 *4. Compute Resilience*

The patient triage api Infrastructure Compute resources must be sized based on capacity testing of an agreed release of the patient triage api applications.

- A specific review must be held for any resource type shown via testing to require different (higher or lower) capacity than the current Production specification.

Each resource in the patient triage api Infrastructure must be subject to periodic 'health checks' - this must be performed on each compute resource type to verify that the node is operating at its expected performance level. Nodes which are determined to be 'unhealthy' must be marked as down or offline so as to prevent jobs from being scheduled or run on them.

- When a node has been detected as offline by the patient triage api Infrastructure, the node must be terminated and another instantiated in its place either manually by human intervention or automatically.

The patient triage api Infrastructure must be able to withstand the loss of a single node in any functional group without any performance degradation or loss of data until the failed node is replaced.

Business Benefit:
Sizing of compute resources within the patient triage api Infrastructure is driven by capacity testing and that those same resources are subject to on-going health checks.

Business Benefit:
The following will be handled gracefully from a user experience perspective:

- a failure in a the presentation Tier in the patient triage api Infrastructure
- a failure in a Application Tier of the patient triage api application architecture supported by the patient triage api Infrastructure
- a failure in a data store in the Data Tier of the patient triage api application architecture supported by the patient triage api Infrastructure

7.10.3.4 *6. External System Resilience*

The patient triage api Infrastructure must be resilient such that patient triage api shall continue to function and recover in the presence of a failure in of an External system or communication to external systems, including:

- Authentication capabilities such as Spine Security Broker (SSB) or CIS2
- Spine Directory Services (SDS)
- NHS.UK
- CareCERT's Security Information and Event Management (SIEM) systems

Business Benefit:
A failure within the patient triage api application architecture supported by patient triage api Infrastructure will be handled gracefully from a user experience perspective.

7.10.3.5 *7. Inter-Tier Resilience*

The patient triage api Infrastructure must be resilient such that the patient triage api shall continue to function and recover in the presence of a failure in:

- the Presentation Tier Load Balancers, whereby traffic into the Web Servers is initially distributed in a round-robin fashion, with subsequent requests from the same session sent to the same instance via sticky sessions
- the Application Tier Load Balancers, whereby traffic into the Application Servers is distributed in a round-robin fashion at all times

Business Benefit:
A failure in cross-tier network traffic utilised by the patient triage api application architecture supported by patient triage api Infrastructure will be handled gracefully from a user experience perspective.

7.10.3.6 8. Graceful Handling of Technical Issues

Should a server-side technical issue occur that inhibits a user's interaction with any patient triage api service, the user will either be logged out of the system, or a message will be displayed to the System User that an error has occurred.

Business Benefit:
More secure user interactions and improved user experience.

7.10.3.7 9. Backups

The patient triage api MUST adopt a defensive position to backups aligning with the NHS England Backup policy[74] which looks to satisfy the NHS England Cyber backup guidance. This MUST cover both the creation of and process of recovery of the back up.

The patient triage api MUST meet the Red Line requirements[75] around Ransomware protection. And MUST regularly take data and code backups[76] to facilitate that.

In all scenarios, backup frequency MUST meet Service Owner's RPO requirements. And restore times MUST meet Service Owner's RTO requirements.

Business Benefit:

Ensures that the service is recoverable in the instance of a catastrophic event or the intent of a back actor.

7.11 NFR: Reproducibility

Software & quality Assurance	Do we have the ability to build, deploy and test applications to a standard quality and in a consistent manner	✅ Performance - live like with old data PUT - smaller with live data Test - very small with test data (up to 8) Pipeline - pipeline destroy these each time.(similar to test) Regression - similar to Test (small with test data)		

74. https://digital.nhs.uk/cyber-and-data-security/guidance-and-assurance/backups-and-office-365-guidance
75. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx#cloud-6
76. https://nhs.sharepoint.com/sites/X26_EngineeringCOE/SitePages/Red-lines.aspx#cloud-5

7.12 NFR: Scalability

7.12.1 1.Background

- *"Scalability is an attribute that describes the ability of a process, network, software or organisation to grow and manage increased demand. A system, business or software that is described as scalable has an advantage because it is more adaptable to the changing needs or demands of its users or clients. Scalability is often a sign of stability and competitiveness, as it means the network, system, software or organisation is ready to handle the influx of demand, increased productivity, trends, changing needs and even presence or introduction of new competitors."* (Source: https://www.techopedia.com/definition/9269/scalability)
- *"... two characteristics of cloud services address two different timeframes in the lifecycle of a business. Cloud elasticity supports short-term, tactical needs, while cloud scalability supports long-term, strategic needs. Cloud elasticity enables businesses to dynamically mitigate variability in demand, along with the peaks and valleys in the demand for an IT service, regardless of whether that service is delivered to internal or external customers. Cloud scalability, on the other hand, enables businesses to meet expected demand for services without the need for large, up-front investments in infrastructure. A healthy business will have its ups and downs over short periods of time, but will continuously go up in the long run."* (Source: http://searchtelecom.techtarget.com/answer/How-do-cloud-elasticity-and-cloud-scalability-differ)

7.12.2 2. Scope

This NFR applies to:

- All components of the API deployed on AWS
- Auto-scaling mechanisms for compute, storage, and supporting services
- Scaling under normal, peak, and unexpected traffic spikes
- Both synchronous (API) and asynchronous (queue/event-based) workloads

---

7.12.3 3. Scalability Objectives Summary

Category	Requirement
Horizontal Scaling	The API must support automatic horizontal scaling via AWS-managed services (Lambda).
Autoscaling Responsiveness	Autoscaling must react quickly enough to maintain the **300 ms P95** latency target for the Triage POST endpoint.

Category	Requirement
Stateless Design	All API components must be stateless to allow rapid scale-out.
Backend Scaling	Datastores (DynamoDB) must scale to support peak throughput without throttling.
Zero Downtime	Scaling events must not impact availability.

7.12.4 4. AWS Scalability Requirements

7.12.4.1 4.1 Compute Scaling

The solution must support automatic compute scaling using AWS-native capabilities:

7.12.4.1.1 using AWS Lambda

- Configure **reserved or provisioned concurrency** to avoid cold start impact at scale.
- Lambda must automatically scale up concurrency to meet traffic demand, maintaining performance targets.

7.12.4.2 4.2 API Gateway / Load Balancer Scaling

- **API Gateway** must be configured to support required steady and burst throughput.
- WAF rate limits must be aligned with expected peak traffic.

7.12.4.3 4.3 Data Layer Scaling

Depending on the implementation:

7.12.4.3.1 DynamoDB

- Must use **auto-scaling** for RCUs and WCUs.
- **Adaptive Capacity** must remain enabled.
- No request throttling allowed during peak load.

7.12.4.3.2 ElastiCache (If required)

- Cluster must scale to support peak traffic (cluster mode enabled if required).

7.12.5 5. Defined Scalability Requirements

The solution shall meet the following scalability requirements:

7.12.5.1 5.1 Core Requirement

> ***The system must automatically scale to handle peak and unexpected increases in traffic without breaching the 300 ms P95 response time requirement for the Triage API triage endpoint.***

7.12.5.2 5.2 Peak Load

The busiest day for completed EP sessions in 2025 was 2025-04-19 - 14605 sessions. The busiest hour was on 2025-04-19 at 11am - 2147 sessions. - Steve Bellerby

The peak load from 2025 was 2,147 completed sessions per hour.

The peak number of journeys in an hour for the 111 Online Emergency Prescriptions in 2025 was: 2,147. So the peak number of transactions that can be expected is:

= (The peak number of journeys per hour x the average journey length) / 3,600

= (2,147 x 11) / 3,600

= 6.56 TPS

This is documented in the API Volumetrics analysis[77].

We are expecting the peak Emergency prescription load to 6.56 TPS. However we will load test the solution to the full production load of 120TPS. This will be more reflective of the load when we have more pathways onboarded.

7.12.5.3 5.3 Additional Requirements

- The solution must handle at least **2×** the normal traffic volume.
- The system must scale out within **N seconds (TBC)** of load increase (based on testing).
- The system must scale back in to control cost without impacting processing.
- Scaling must not degrade availability.
- No manual intervention should be required for scaling.

77. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1237092742/API+Volumetrics+analysis

7.12.6 6. Monitoring & Observability Requirements

Area	AWS Requirement
Scaling Metrics	CPU, memory, RPS, concurrency, queue length monitored via CloudWatch.
Scaling Alerts	Alert if autoscaling fails to trigger or hits max limits.
Tracing	Use AWS X-Ray to identify scaling bottlenecks.
Dashboards	ODIN dashboards for scaling events, saturation, concurrency.

7.12.7 7. Scalability Testing Requirements

7.12.7.1 Required Tests

- **Load testing** to validate scaling and ensure P95 latency stays < 500 ms for peak load.
- **Spike testing** to validate handling of sudden increases.
- **Stress testing** to identify scaling ceilings (max concurrency, etc.).
- **Failover scaling tests** if using multi-AZ or multi-region.

7.12.7.2 AWS-Specific Tests

- Lambda concurrency scaling tests
- DynamoDB scaling under peak RCU/WCU
- API Gateway throttling and burst capacity validation

7.12.8 8. Risks & Assumptions

7.12.8.1 Risks

- AWS throttling due to insufficient service limits
- Downstream systems failing to scale at the same rate
- Cold starts (if using Lambda) impacting response time at scale
- Incorrect autoscaling thresholds causing delayed scale-out

7.12.8.2 **Assumptions**

- All services use AWS recommended scaling patterns
- Architecture remains stateless
- Traffic forecasts are reasonably accurate
- AWS service quotas are pre-increased for high traffic loads

7.13 NFR: Security

7.13.1 Background

- Security is paramount to Patient Triage Api due to being deemed a Priority Application and Mission Critical Infrastructure.
- *"Cybersecurity, computer security or IT security is the protection of computer systems from theft of or damage to their hardware, software or electronic data, as well as from disruption or misdirection of the services they provide."* (Source: https://en.wikipedia.org/wiki/Computer_security)
- *"Network Security is the process of taking physical and software preventative measures to protect the underlying networking infrastructure from unauthorised access, misuse, malfunction, modification, destruction, or improper disclosure, thereby creating a secure platform for computers, users and programs to perform their permitted critical functions within a secure environment."*(Source: https://www.sans.org/network-security)
- *"Application security is the use of software, hardware, and procedural methods to protect applications from external threats."*(Source: https://searchsoftwarequality.techtarget.com/definition/application-security)
- *"A cryptographic key is a piece of information (a parameter) that determines the functional output of a cryptographic algorithm."*(Source: https://en.wikipedia.org/wiki/Key_(cryptography))
- *"Key management is administering the full lifecycle of cryptographic keys and protecting them from loss or misuse. The lifecycle includes: generating, using, storing, archiving, and deleting of keys."* (Source: https://info.townsendsecurity.com/definitive-guide-to-encryption-key-management-fundamentals)
- A security certificate is allotted to a website or Web application by a third-party certification authority. In Patient triage Api certificates are used to provide verification to professional, authority users that they are interacting with NHS England-owned resources.
- *"A certificate... is an electronic document used to prove the ownership of a [public] key. The certificate includes information about the key, information about the identity of its owner (called the subject), and the digital signature of an entity that has verified the certificate's contents (called the issuer). If the signature is valid, and the software examining the certificate trusts the issuer, then it can use that key to communicate securely with the certificate's subject."* (Source:_ https://en.wikipedia.org/wiki/Public_key_certificate)

- *"Digital certificates are important for establishing trust and conforming to security protocols, so it follows that the management of such certificates is a very important process. The certificate authority (CA) has the right to create and issue certificates to those that request them. Issued and accepted certificates are marked as valid through publication to a certificate repository, another entity which keeps records of valid certificates with attributes like validity period and owner."*(Source:_ https://www.techopedia.com/definition/29705/certificate-management)
- *"Access management (AM) is the process of identifying, tracking, controlling and managing authorised or specified users' access to a system, application or any IT instance. It is a broad concept that encompasses all policies, processes, methodologies and tools to maintain access privileges within an IT environment."* (Source: https://www.techopedia.com/definition/28004/access-management-am)

7.13.2 Assumptions

- All requirements relate to *all* environments:
  - Pre-Production environments as these are used during the software development process.
  - Production environment as this is the environment in which Patient triage Api users directly interact.

7.13.3 Acceptance Criteria

7.13.3.1 *1. Overall Security*

This requirement seeks to ensure solution adherence to NHS England security policy.

- 1.1. The 'NHSE Approved Cryptographic Algorithms GPG v4.0' specification MUST be met by any approach to privacy and security based on encryption. This implies that:
  - 1.1.1. Patient triage Api should encrypt data within the application
  - 1.1.2. The Cloud hosting provider should further encrypt data within the Patient triage Api Infrastructure
- 1.2. The solution SHOULD consider the recommendations in the security pillar a Well-Architected Framework such as AWS or Azure (i.e. security pillar[78])which provides guidance to help apply best practices to secure environments in all phases of development: design, delivery, and maintenance.

78. https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html

7.13.3.2 *2. Data Security*

This requirement seeks to ensure that Patient triage Api data is secure when stored and when transferred.

- 2.1. The Patient triage Api Infrastructure MUST protect:
  - 2.1.1. data in transit i.e. data actively moving from one location to another such as across the internet or through a private network.
  - 2.1.2. data at rest i.e. data that is not actively moving from device to device or network to network such as data stored in a database, object store or archived/stored in some other way.
- 2.2. The Patient triage Api Infrastructure MUST ensure:
  - 2.2.1. each environment can only access its own data
  - 2.2.2. direct human access to data is not possible

7.13.3.3 *3. Network Security*

- 3.1. To help address network security, each compute resource in the Patient triage Api Infrastructure MUST be protected by a firewall rule. To ensure that only relevant resources within the Patient triage Api Infrastructure can communicate with each other, firewalls rules:
  - 3.1.1. will be built on as needed basis with least privilege access from a precedence perspective
  - 3.1.2. will not allow access from subnet(s)
- 3.2. Incoming and outgoing network connections to the Patient triage Api Infrastructure MUST be secured. This includes:
  - 3.2.1. VPN connectivity
  - 3.2.3. public internet connectivity

7.13.3.4 *4. Application Security*

This requirement stipulates the need for measures to be taken during the delivery process to help ensure that the Patient triage Api applications are secured.

- 4.1. Patient triage Api SHOULD be de-risked by guidance from:
  - Level 1 and Level 2 OWASP Application Security Verification Standard as defined by Open Web Application Security Project (OWASP)[79]
  - monitoring against the CIS Benchmarks[80] for Amazon Web Services
- 4.2. NHS England SHOULD arrange the independent penetration testing of Patient triage Api by an external party prior to implementing any significant change AND every 12 months inline with NHS Data Security Protection Toolkit (https://www.dsptoolkit.nhs.uk).

79. https://owasp.org/www-project-application-security-verification-standard/
80. https://www.cisecurity.org/

- 4.3. The security measures implemented by Patient triage Api Infrastructure MUST be unobtrusive and not interfere with legitimate access to applications and data required by their Business Function. i.e. Security must be balanced against application usability, without detriment to services, and within its agreed operating parameters.
- 4.4 Access to Patient triage Api Application resources MUST be achieved through a combination of technology and operations (management procedures) using clearing defined NHS England IAM policies.
- 4.5 Access to Patient triage Api Application resources MUST be able to be granted to both people (human users) and processes (system users).
- 4.6 Authentication for people and processes to access Patient triage Api Application resources MUST be achieved with identities (users, roles, groups) using clearing defined NHS England IAM policies.

7.13.3.5 *5. Key Management*

This requirement seeks to ensure that a secure approach is taken to managing the keys utilised by the components within the Patient triage Api architecture.

- 5.1. The Patient triage Api Infrastructure MUST:
  - 5.1.1. protect cryptographic keys by limiting access to the keys physically, logically, and through user-based and role-based access
  - 5.1.2. allow administrators to create, delete and control keys that encrypt data stored within the Infrastructure

6. Certificate Management

- 6.1. The Patient triage Api Infrastructure MUST:
  - 6.1.1. allow certificates to identify and secure communication between Patient triage Api resources
  - 6.1.2. allow administrators to be informed of certificate expiry and to introduce and apply new certificates

7. Infrastructure Access Management

- 7.1. Access to Patient triage Api Infrastructure resources MUST be achieved through a combination of technology and operations (management procedures).
- 7.2. Access to Patient triage Api Infrastructure resources MUST be able to be granted to both people (human users) and processes (system users).
- 7.3. Authentication for people and processes to access Patient triage Api Infrastructure resources MUST be achieved with identities (users, roles, groups).

8. Supplier Security

- 8.1. The Supplier MUST ensure that:

    - 8.1.1. Any networks and services under its control and used in the provision of services are protected from external access.
    - 8.1.2. Only entities known and agreed by the Authority are permitted to access networks.
    - 8.1.3. Logical network separation exists between Authority applications and services and those provided for other customers by the Supplier.
    - 8.1.4. Any networks under its control and used in the provision of services, authenticate all connections to and from any remote servers and applications including via the Internet. Authentication shall use Authority-provided Electronic Digital Certificates.
    - 8.1.5. Access to diagnostic ports and tools for any networks under its control and used in the provision of services are securely controlled (i.e. subject to the Security Policies of the Supplier and the Authority.
- 8.2. The Supplier MUST ensure, for systems under its control and used in the provision of services, that:
    - 8.2.1. Access to system and software utility programmes is protected from unauthorised use.
    - 8.2.2. Only entities known and agreed by the Authority are permitted to access these system and software utility programmes.
    - 8.2.3. The distribution, execution and audit of applications is accomplished in such a way as to prevent the execution of applications which have not been approved.
    - 8.2.4. The distribution, execution and audit of applications is undertaken by a unique user account, traceable to a unique individual.
    - 8.2.5. For systems under its control and used in the provision of services, that all code and data is maintained securely at all times (including during transfer).

9. Patient Identifiable Data

- 9.1 All confidential Patient Identifiable Data (PID) must be securely encrypted whilst in transit. All connections must be assumed to operate on untrusted networks, therefore all external connections must undergo mutual authentication and encryption unless agreed as an exception (e.g. infrastructure services such as NTP and DNS).
- 9.2 External APIs must not expose Patient Identifiable Data in an unencrypted form.

PID is defined as:

> *Information that, either on its own or in conjunction with other data, can be used to identify an individual.*
>
> *Patient Identifiable Data (PID) can be any combination of data items that could be used to identify a patient directly, indirectly or in combination. Examples of key identifiable information that could be combined to produce PID includes:*
>
> - Patient's name, address, full post code, date of birth.

> - This may appear directly within a Request or be contained in information associated with the Request (e.g. as an attachment or comment).
> - Pictures, photographs, videos, audio-tapes or other images of patients.
>   - This may appear as an attachment to a Request.
> - NHS numbers and local patient identifiable codes;
> - Anything else that may be used to identify a patient, or at least narrow down their identification to a small number of possibilities, directly or indirectly. For example,
>   - A known appointment time at a known Service or a time known within a narrow window.
>   - Rare diseases, drug treatments or statistical analyses which have very small numbers within a small population may allow individuals to be identified.
>   - Rare attributes such as a Patient who opts for 'fax' communication rather than the common options of telephone or email or a patient whose preferred language is rarely used in PDS.
>
> *Typically, these single data items in isolation often wouldn't enable a patient to be identified as a patient (e.g. an NHS number alone would be realistically meaningless, and as such isn't PID).*

Business Benefit:
PID is highly confidential and as such needs to be protected from inappropriate observation and tampering.

10. Penetration Testing

- 10.1 The Patient triage Api must support automated penetration testing as a means of providing early sight of potential security vulnerabilities. The Patient triage Api dependencies will be analysed to determine if each of them has any published vulnerabilities, flagging via the build accordingly.
- 10.2 Test results must be included as part of the environment's reporting such that test failures are apparent and can be investigated. Test failures should block the implementation of the overall release until the issue is triaged and its priority agreed. Execution time to complete the tests must be reasonable and manageable i.e. the time taken must be minimised such that it can be run regularly and provide useful results.
- 10.3 The approach will focus on OWASP A06:2021 Vulnerable and Outdated Components[81]. Components, such as libraries, frameworks, and other software modules, almost always run with full privileges. If a vulnerable component is exploited, such an attack can facilitate serious data loss or server takeover. Should Patient triage Api utilise components with known vulnerabilities, application defences may be undermined to enable a range of possible attacks.

It is recognised that NHS England will arrange the independent penetration testing of Patient triage Api by an external party at various intervals. At least annually and at and significant change to the security perimeter.
The External APIs will undergo penetration testing by an external specialist in a live-like scenario.

81. https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

Business Benefit:
Security penetration testing is vital for a system containing confidential information where clinical safety of Patients data can potentially be compromised.
Early detection and resolution of any vulnerability is advantageous.

7.14 NFR: Sustainability

Suitable logging, analytics and dashboards are in place to allow on-going measurement of sustainability targets.

In this way, the sustainability pillar[82] of the AWS Well-Architected Framework can be considered and applied to help drive environmental efficiencies in cloud environments in all phases of development: design, delivery, and maintenance.

Business Benefit:
NHS England can monitor environmental impact associated with managing the entire Patient Triage Api, allowing on-going refinements to usage and infrastructure to be made.

7.15 NFR: Version Control and Release Management

This page outlines a proposed high level approach to version control and release management for the Triage API. A more detailed specification will be developed as part of the implementation guidance to be published alongside the API technical specification.

7.15.1 Version control

Version control in the Triage API relates to three layers of versioning:

Layer	E.g.	Update frequency	Location	Notes
FHIR Schema	R4	Static	URL (e.g. `/FHIR/R4/`)	Should not change once live.
API Schema	2.0.0	Infrequent updates	Capability Statement	Frequent changes are expected during the Alpha and Private-Beta phase to reflect iterative improvements by the team. Changes may include breaking changes although the aim will be to avoid these. Once the Triage API enters Public Beta and Live it is expected the change frequency will be minimal and due consideration to the impact of changes on API consumers.

82. https://docs.aws.amazon.com/wellarchitected/latest/sustainability-pillar/sustainability-pillar.html

Layer	E.g.	Update frequency	Location	Notes
Clinical Logic	49.0.0	Frequent updates	Accept Header	Relates to the Release version of Pathways Clinical Logic used by the Triage API Triage Engine. Up to weekly cadence; impacts user training and assurance. Could impact on re-hydration between care settings if there is a version mismatch and the rehydrating site has not opted in to a later version.

Version control in the Triage API will follow the current API management standard, as follows:

- Use the URL path to indicate any industry standard and version, e.g. /my-api/FHIR/R4
- For selecting the logic version, use the "version" parameter in the accept header, e.g. "**application/fhir+json; version=2**"
  - For the first version, no version is required - only add it for version 2 onwards
  - The logic version is for **major** versions only. As this is defined based on SemVer, a minor version is non-breaking and therefore it does not need to be specified

Full details of this standard can be found here https://nhsd-confluence.digital.nhs.uk/spaces/APM/pages/144742522/Version+control

7.15.1.1 *API Schema version vs Pathways Releases (clinical business logic)*

APIM guidance states to avoid versioning within the URL and to use the 'version' parameter in the accept header. Logic version here relates to the API schema and affects the client at the system level. Schema changes will be relatively infrequent once the API exits beta phase.

Pathways releases are part of 'Business As Usual' activity reflecting clinical authoring updates. Currently these occur on a 12 weekly basis but are planned to increase in frequency to as required - potentially weekly or daily for minor changes. Providers must opt in to new Pathways Releases to align with staff training. It is expected that minor or non user / clinically significant changes will not require a config change to opt-in.

7.15.1.2 Negotiating API Schema

Reference: BaRS Versioning policy[83]

- Defined in the **Capability Statement** and used to establish compatibility at the start of all triage encounters. An encounter here being a single care setting interaction between a patient and healthcare provider in the context of performing a triage.
- The API Schema version reflects structural changes to the API, including things like payload format, cardinality

83. https://simplifier.net/guide/nhsbookingandreferralstandard/Home/About-BaRS/Versioning?version=1.9.0#gsc.tab=0

- Updates are infrequent and *may* include breaking changes
- Versioning follows Semantic Versioning (SemVer):
  - Major: breaking changes
  - Minor: non-breaking enhancements
  - Patch: bug fixes
- API consumers will call a /metadata endpoint and receive a FHIR CapabilityStatement response with details of all the required items that must be present for the desired workflow (Version, Functions, MessageDefinitions). If present, the workflow can continue. Else, the API consumer should stop.

7.15.1.3 Specifying Clinical Logic

- Specified via the version parameter in the Accept header, e.g. `Accept: application/fhir+json; version=49`
- Applies only to major logic versions; minor updates are backward-compatible and do not require explicit versioning
- Logic updates are expected to occur frequently, up to daily or weekly, with clinical safety sign-off and regression testing
- The API response will carry the version of the Pathways Release the logic relates to and the consuming system must check this for consistency as part of local state management. If this does not align the consuming system should stop

7.15.2 Parallel Versioning

- A version retirement policy is still to be decided but should be defined and signed up to as part of onboarding and conformance
- The policy should define a deprecation roadmap for each major version (e.g. 6 months)
- We can monitor version usage and volumes and tie this back to suppliers using APIM.

7.15.3 Deployment Management

How deployments are managed across environments and regions.

Note the below proposal is post alpha phase. During alpha we should be focused on realistically proving the POC but with the mindset that this is throw away. Therefore the effort in automating pipelines should be proportionate.

Proposal

- There shall be two chains of deployment, split into lower and higher environments.
- Lower environments are triggered by a merged Pull Request in GitHub
- Higher environments are triggered by publishing a Release in GitHub.

The following environments will be used in the release process:

Env name	Purpose	Change frequency	Deployment Level	Account
Sandbox	Published to Developer pages via APIM. Stubbed responses. No persisting of data. No underlying infrastructure.	Infrequent. Per API schema change.	Lower	Develop
Local	Local development	Frequent. E.g. per code merge.	Lower	local
Dev	Shared development environment	Frequent. E.g. per code merge.	Lower	Develop
Test	Test environment - if needed post alpha phase	Frequent. E.g. per code merge.	Lower	Test
Int	Integration environment. Early adopter testing.	Every production release	Higher	Test
Pre-prod / Ref	Aka Ref environment. Mirror production environment as closely as possible.	Every production release	Higher	Test
Prod	Live production environment handling production traffic.	Every production release	Higher	Prod

7.15.4 CI CD Deployment

Development and Release Processes[84]

7.15.5 Release Management

Releases include:

- Changes to Triage API Schema
- Changes to Clinical logic - Pathways Releases
- Concept maps published to NHS England Terminology Server for mapping between proprietary SG, SD, DX codes and new Triage Outcome Model
    - Further details on mapping release process: ADR-TOM-005: Release Management Options for Triage Mappings[85]

84. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1244175590/Development+and+Release+Processes#DevelopmentandReleaseProcesses-Releaseprocess

Requirements

- Releases of both API logic and Pathways Releases follow semantic versioning practices
- Regression testing is performed
- Clinical safety sign-off or other approving release board is performed for each major release
- Release notes published publicly
- New releases deployed will not affect active triage sessions. Connecting clients must opt-in to major clinical logic versions via config by using the "version" parameter in the accept header or by negotiation of the FHIR CapabilityStatement.

A detailed release process is still to be defined.

7.15.6 Patch Management

Hot fixes and non-breaking changes process are still to be defined. This depends on the nature of the patch and change being released for example:

- Is it a minor or major change
- Does it impact clinical safety
- Does it impact api consumers or end users?
- Is the change part of API schema or clinical logic?

7.15.7 Hot Fix Release

Patient Triage Api - Hotfix Strategy (Fix Forward)[86]

7.15.8 Date Time Configuration

Handling of time stamps - refer to FHIR guidance and alignment.

7.15.9 Seasonal Time Adjustments

- Systems must operate in UTC only to avoid confusion
- It is the responsibility of the connecting party to account for Time Zone changes and daylight saving logic.

7.15.10 Verification of Code Quality

The detailed testing processes will be defined in later phases but should include:

85. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1113379489/ADR-TOM-005+Release+Management+Options+for+Triage+Mappings
86. https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1314202210/Patient+Triage+Api+-+Hotfix+Strategy+Fix+Forward

- Automated testing tooling, integrated as part of CI/CD:
  - Linting
  - Sonarqube
  - Chekov
  - Etc - Refer to engineering community guidelines and org best practice
- Local unit tests
- Scenario testing
- Automated regression testing
- FHIR Validation checking

The level and types of test will differ depending on the environment.

7.15.11 Backups and Rollbacks

Requirements to be defined in more detail

- Alignment with Engineering Red Lines and SA Framework E.g.:
  - All releases to be stored in immutable repositories (e.g. AWS S3)
  - Disaster Recovery & Business Continuity. There should be clear requirements (commensurate with service levels) around DR & BC (and a pragmatic approach taken with regards DR/BC events planned for).
    Continuity plans and supporting documentation should reflect the requirements, technical & architecture constraints etc.

Backups to include:

- Logic artefacts
- API configuration snapshots

Rollbacks:

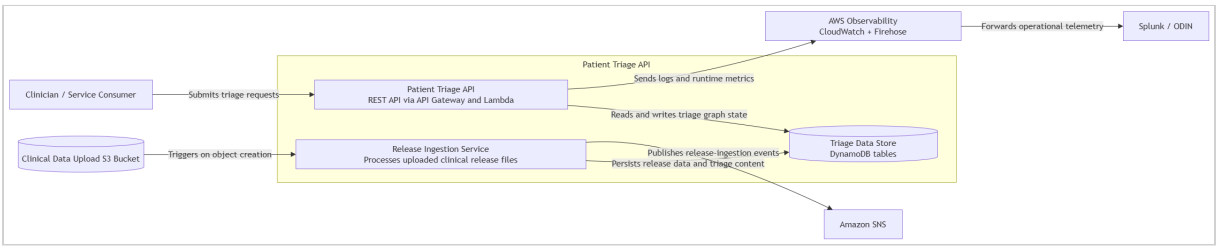
- Are automated for code failures (via CI/CD pipeline)
- Manually triggered if clinical safety is impacted

Include process for break glass, emergency reversion and notification protocol to be defined.

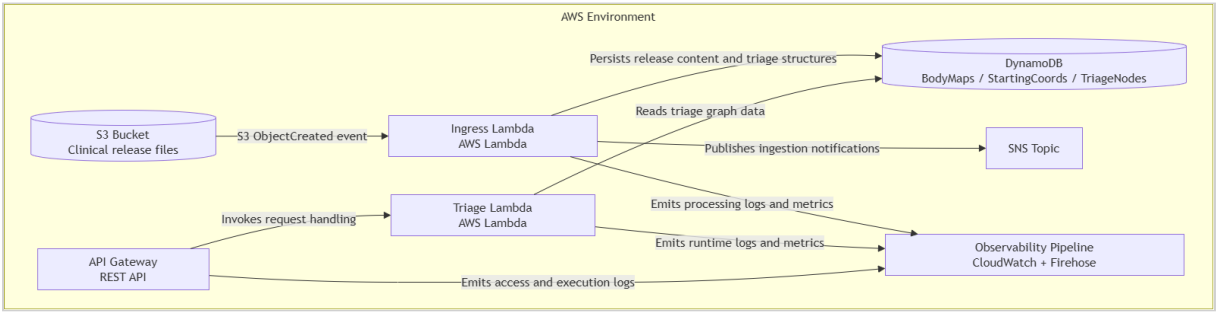
8 Patient Triage API Architecture C4 Model

This C4 view shows the solution at the system context and container level, based on the AWS and Lambda architecture defined in the repository.

8.1 System Context



8.2 Container Diagram



8.3 Notes

- The solution follows a hexagonal architecture internally, but this C4 diagram reflects the deployed AWS shape of the service.
- The ingress path is triggered by object creation in the clinical upload bucket.
- The triage path is served by API Gateway and Lambda, with the primary state persisted in DynamoDB.
- Operational telemetry is streamed through CloudWatch and Firehose for downstream monitoring and analytics.

9 Solution Architecture Framework Review October 2025

9.1 Context

An NHSE SAF assessment was completed at the end of October 2025.

Link to the file in the SA Profession sharepoint: NHS England SAF Assessment - Patient Triage API Oct 2025.xlsx[87].

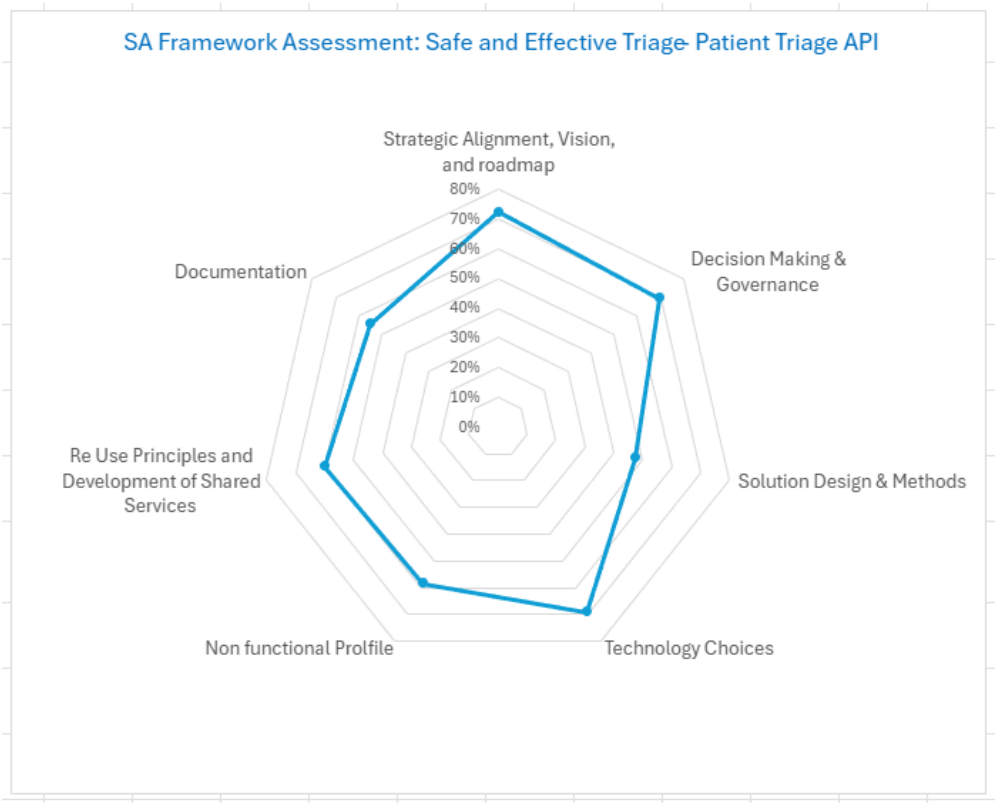
Note, this is a point in time assessment at the point of exiting GDS Alpha and entering GDS private beta phase.

The assessment will be re-run during the Private Beta phase ahead of go-live, currently anticipated for end of April 2026.

9.2 Assessment Summary

SA Framework Assessment: Safe and Effective Triage - Patient Triage API							Oct 2025
Dimensions	% Compliance	0	1	2	3	4	5
Total issues		0	0	4	22	11	1
Strategic Alignment, Vision, and roadmap	72%	0	0	0	2	1	1
Decision Making & Governance	69%	0	0	0	5	3	0
Solution Design & Methods	47%	0	0	1	6	5	0
Technology Choices	69%	0	0	0	2	1	0
Non functional Prolfile	59%	0	0	1	4	0	0
Re Use Principles and Development of Shared Services	60%	0	0	1	1	1	0
Documentation	55%	0	0	1	2	0	0

87. https://nhs.sharepoint.com/:x:/s/msteams_9e4bf8/IQCgWuYFWTDMSrx-jmRdM9UrAe-EUU6rV3yyba3_nS9lhSU?e=xL44RY



9.3 Actions

Several actions have been identified which is to be expected, particularly as this is a new service and the maturity level is currently low due to alpha/beta phase.

With this in mind, the current actions that should be considered are:

Criteria	Description	Evidence	Mitigations	Score	Action	Status
S03, S04	A well-formed and maintained product vision and roadmap should exist with appropriate detail around architecture elements.	https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/917496069/Vision+Goals https://nhs.sharepoint.com/:p:/s/msteams_9646b6/EQFk6NImEBRIpLGI83DWU2YBhRfjaDSjCa9qiZjnWIjBdQ?e=oVMRvX	Documents are distributed between confluence and sharepoint. Need to be in one coherent place	3	Centralise product vision, roadmap, and architecture artefacts into a single Confluence/ SharePoint location	
DM01	Where a solution or part of solution is seen as tactical, short term or introduces / persists tech & architecture debt, remediation plans should be in place and agreed with the relevant stakeholders and governance groups. Architecture Debt should be identified with implications, rationale and future mitigation plans (recorded in an Architecture Debt Register) Plans should be realistic and funded.	Risks and Architecture Decisions Log maintained in Confluence and reviewed in Technical Design Authority, but no Architecture Debt Register maintained. Raid log: https://nhs.sharepoint.com/:x:/r/sites/msteams_9646b6/_layouts/15/Doc2.aspx?action=edit&sourcedoc=%7Ba0a10b0a-9d9d-44e1-9019-82b79e953287%7D&wdOrigin=TEAMS-MAGLEV.undefined_ns.rwc&wdExp=TEAMS-TREATMENT&wdhostclicktime=1761648641112&web=1 https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/938127576/7.1.2.1+Decision+Records	Setup Arch Debt Register	3	Create and maintain an Architecture Debt Register. Seek out best practice for how to manage and maintain this.	

Criteria	Description	Evidence	Mitigations	Score	Action	Status
DM02	Spend control (GaTS) and associated Government Digital Services & Service Design related guidance should be followed whilst developing the solution and be evidenced for service design & spend control reviews.	GaTS documentation: https://nhs.sharepoint.com/:w:/s/msteams_9646b6/EbF7cmUT06RDhHPyvwsWTngB5pV7Is6D4A2tFRT0fK-IhA?e=YZm9Y4 https://nhs.sharepoint.com/sites/msteams_9646b6/Shared%20Documents/General/Project%20Governance-Plans,%20SoWs,%20RAID/TaDa%20and%20GaTS/Team%20Griffin%20GatS%20Evidence%20Board_2025-06-15.pdf	To be added TaDa documentation	3	Complete Spend Control (TaDa) documentation and link with GaTS evidence.	
DM03	Architecture risks and issues should be managed effectively with the appropriate level of visibility and ownership.	RAID LOG: https://nhs.sharepoint.com/:x:/r/sites/msteams_9646b6/_layouts/15/Doc2.aspx?action=edit&sourcedoc=%7Ba0a10b0a-9d9d-44e1-9019-82b79e953287%7D&wdOrigin=TEAMS-MAGLEV.undefined_ns.rwc&wdExp=TEAMS-TREATMENT&wdhostclicktime=1761648641112&web=1	Highlight arch and tech risks on RAID log so that they are more visible	4	Tag or flag architecture risks explicitly within RAID and review regularly at RAID meeting.	
SD01	An appropriate design methodology should be followed e.g. Domain Driven Design and should include NHS/CDDO Service Design and Secure by Design principles and methods.	Overarching design methodology not quite in place. Ideas of DDD, service design etc do flow through individuals. Future processes being put in place and is being addressed by transformation work		3	Seek out more guidance on this. Assess against SbD principles as should be aligned.	

Criteria	Description	Evidence	Mitigations	Score	Action	Status
SD 04	Solution design should follow good practice design principles. E.g. Separation of concerns; Encapsulation / Modularisation; Loose coupling; High cohesion / single responsibility; Design for flexibility/change; Etc.	Solutions for the triage API is considering serverless design with modulariation and separation of concerns	Ongoing, in alpha phase still	3	Consider extending design documentation for triage engine architecture and key design patterns. Beta phase now.	
SD 08	We should select the correct patterns for the use case, and any trade-offs justified and agreed.	These are documented in ADRs and LLD https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/917175957/7.1.2+Decision+Logs https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1148657021/7.2.1.1+Triage+Engine+Architecture	Even though some documentation is present more documentation needed	3	Ensure ADRs comprehensively cover versioning strategy, deprecation/ sunsetting, major design patterns, and rationale for architectural choices. There has been progress on this recently, if core areas covered then this score should move up.	
SD 12	The relevant cloud "Well Architected Framework" should be followed, and the solutions assessed against it. (Note there are overlaps with the Engineering Software Quality Framework; ensure a consistent response and do not repeat assessments)	AWS Well architected framework was applied when selecting appropriate infrastructure for the triage api		3	Prioritise and conduct an AWS architecture assessment now the service has entered private beta phase.	

Criteria	Description	Evidence	Mitigations	Score	Action	Status
NF01	Solutions should incorporate workload observability and understand service health.	https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1128208069/7.1.5.3+Observability+Monitoring+Metrics+Dashboards+and+Alerting (see page 64) https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1180223698/ADR-018+Monitoring+and+Observability+Tooling https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1180223741/ADR-019+WIP+Alerts https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1180223784/ADR-020+WIP+Metrics		3	Implement compliant logging and monitoring in private beta. Track as part of completed actions out of this assessment.	
NF02	Reliability & Resilience needs should be defined (in terms of standard NHS England service levels) and solution mechanisms to meet these needs are defined including metrics such as RTO, RPO etc.	https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/917175969/7.1.5+Non-Functional+Requirement+NFR (see page 44) https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1180224379/ADR-022+Disaster+Recovery+and+Business+Continuity		3	Expand DR/BC plans with realistic scenario walkthroughs (APIM outage, regional failure, downstream service loss) and align with NHS SLAs. This is required part of private beta and Live Service onboarding.	

Criteria	Description	Evidence	Mitigations	Score	Action	Status
D01	All architecture documentation should be maintained (with supporting processes and change control) within the appropriate NHS England knowledge store(s) e.g. Aalto, SharePoint, Confluence.	All documentation is in confluence and sharepoint	Need to add an aalto diagram (biz design)	3	Update aalto with accurate diagram. Consider how to model future state.	
D02	Documentation should be published "open by default" and exceptions handled according to policy i.e. sensitivity etc.	Currently permission-based access to documentation	Need to look at models which is open by default on existing documentation	2	Action - make repo public. Now actioned (Jan '26).	

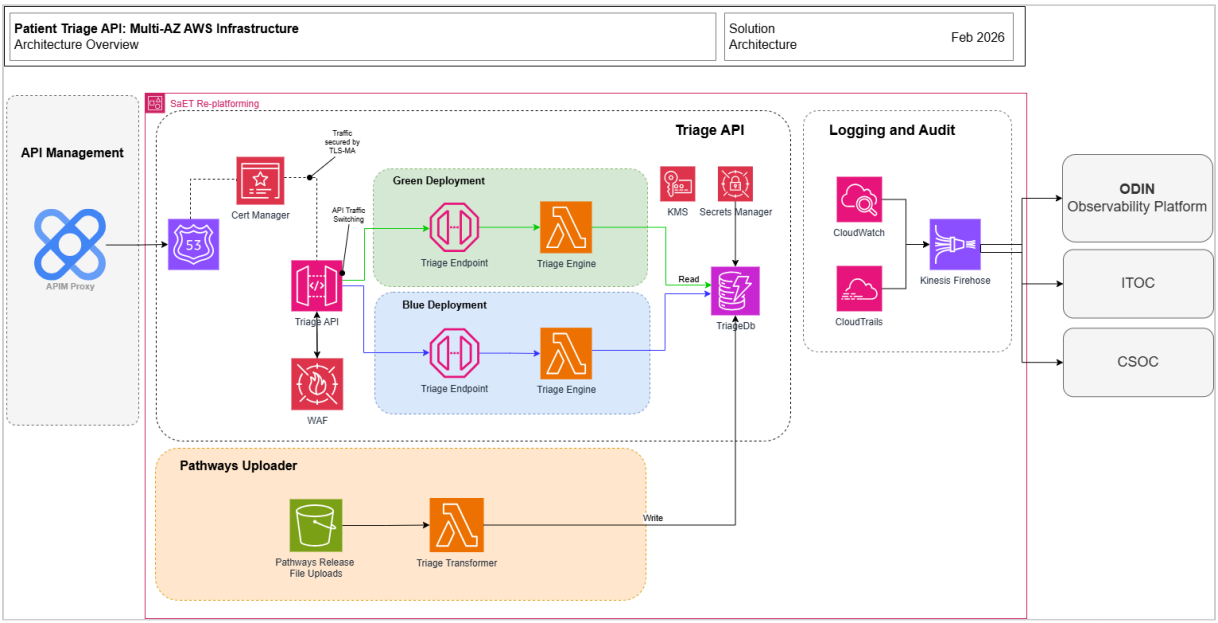
Criteria	Description	Evidence	Mitigations	Score	Action	Status
D03	The architecture documentation should be appropriate in scope and quality for the solution covering (but not exclusively): • Architecture Vision • Architecture Roadmap • Layer Diagrams • Capability Model and Solution Mapping • Non functional requirements • Conceptual Architecture • Logical Architecture • Physical (including network, infrastructure etc.) • Solution Architecture Overview (SDO) • Key Architecture Decisions (KADs) • Data Models • Data Flows • API Specifications • Volume and Performance Models • Architecture Decision Records • Assumption, Risks, Issues and Dependencies • Cyber Assessment Framework compliance	Following documents are missing and need to be added in: • Architecture Vision • Architecture Roadmap • Layer Diagrams • Capability Model and Solution Mapping • Cyber Assessment Framework compliance [provide links]	Complete missing documentation	3	Review items mentioned, create where missing. Develop and publish missing architecture documents including Architecture Vision, Architecture Roadmap, layered architecture diagrams, capability mapping to NHSE Business Capability Model, and Cyber Assessment Framework compliance view. Supports S02, S03	

Criteria	Description	Evidence	Mitigations	Score	Action	Status
NF04	Audit & logging requirements should be defined, and the solution can support them. NCSC Logging and Protective Monitoring; NCSC Principle 13: Audit information and alerting for customers	https://nhsd-confluence.digital.nhs.uk/spaces/NPR/pages/1128208069/7.1.5.3+Observability+Monitoring+Metrics+Dashboards+and+Alerting (see page 64)	NCSC be added in private beta phase	2	Action - ensure requirement carried through to Beta	
SD10	The API follows the lifecycle policy best practice as set out within Sunsetting (deprecation and retirement) policy. This should include any enforcement arrangements.	ADR around API versioning includes deprecation policy. Documentation needs to be improved as not everything has been documented yet	Complete ADRs	2	Identify ADR gaps and complete	
RU02	For new capabilities we should identify/ recognise the potential reuse opportunities which may drive design decisions, benefits etc.	To early to say as we are in alpha	Will be considered when Authoring Tools alpha is kicked off	2	Consider as part of beta phase / authoring workstream once it begins. Feed this in as a potential requirement.	

10 Triage API Infrastructure

- Triage API - Multi-AZ (see page 107)
- Triage API - Multi-Region (see page 108)

10.1 Triage API - Multi-AZ



10.2 Triage API - Multi-Region

